

4. Web Application Security Testing

4.0 مقدمه و اهداف

ارزیابی امنیتی وب اپلیکیشن با هدف شناسایی، تحلیل و ارزیابی آسیب پذیری های امنیتی موجود در لایه های مختلف Application، شامل لایه زیرساخت، پیکربندی و استقرار، مدیریت هویت، احراز هویت، کنترل دسترسی، مدیریت نشست، اعتبارسنجی ورودی، مدیریت خطا، رمزنگاری، منطق کسب و کار و قابلیت های سمت Client انجام شده است.

روش شناسی آزمون بر اساس **OWASP Web Security Testing Guide (WSTG) v4.2** طراحی شده و طی آن سعی شده است سطح حمله Application از دیدگاه یک مهاجم خارجی مورد ارزیابی قرار گیرد.

در جریان ارزیابی، مواردی از قبیل Endpoint های قابل دسترس، پارامترهای ورودی، Header، HTTP Methods، Cookie ها، مکانیزم احراز هویت و Authorization، فرآیندهای مدیریت حساب کاربری، مکانیزم Session، File Upload، رفتار Application در مقابل ورودی های غیرمنتظره، خطاهای سمت Server و Client، نحوه ارتباط با سرویس های Backend و سایر مؤلفه های امنیتی مورد بررسی قرار گرفتند.

بر اساس نتایج حاصل از آزمون ها، آسیب پذیری قابل بهره برداری در محدوده تست های انجام شده شناسایی نگردید.

4.1 Information Gathering

4.1.1 Conduct Search Engine Discovery Reconnaissance for Information Leakage

هدف و شرح آزمون

هدف این آزمون شناسایی اطلاعات حساس یا داخلی درباره Application از طریق موتورهای جستجو و منابع عمومی است. اطلاعاتی نظیر صفحات مدیریتی، فایل های پشتیبان، فایل های Configuration، مستندات داخلی، اطلاعات کاربران، Error Message ها و Endpoint های غیرمستقیم می توانند از طریق Index شدن توسط موتورهای جستجو در اختیار مهاجم قرار گیرند.

روش آزمون

دامنه و منابع عمومی مرتبط با Application از طریق Query های متداول Search Engine و بررسی نتایج Index شده مورد ارزیابی قرار گرفتند. مواردی از قبیل فایل های حساس، صفحات Administrative، مستندات داخلی، Directory Listing، فایل های Backup و اطلاعاتی که نباید در سطح عمومی قابل مشاهده باشند مورد بررسی قرار گرفتند.

نتیجه و تحلیل

اطلاعاتی که بتواند منجر به افشای داده حساس، دسترسی به منابع داخلی یا افزایش معنادار سطح حمله Application شود مشاهده نگردید. همچنین منابع حساس یا فایل های Configuration در نتایج عمومی قابل دسترسی مشاهده نشدند.

نتیجه: Secure – آسیب پذیری شناسایی نشد.

Fingerprint Web Server 4.1.2

هدف و شرح آزمون

Fingerprinting با هدف شناسایی نوع و نسخه Web Server انجام می شود. افشای Version دقیق Web Server می تواند به مهاجم در شناسایی CVE های مرتبط و طراحی حملات هدفمند کمک کند.

روش آزمون

الگوهای اختصاصی Web Server بررسی شدند. HTTP Response Header ها، Error Response ها، Banner ها، رفتار Server در برابر Request های مختلف و

نتیجه و تحلیل

اگرچه اطلاعات عمومی مورد نیاز برای عملکرد صحیح سرویس در Response ها وجود داشت، اطلاعات افشاشده امکان شناسایی یک Version آسیب پذیر یا یک مؤلفه دارای آسیب پذیری شناخته شده را فراهم نکرد. همچنین در Response های خطا اطلاعاتی که مستقیماً Version دقیق مؤلفه های Backend را آشکار کند مشاهده نشد.

نتیجه: Secure.

Review Webserver Metafiles for Information 4.1.3 Leakage

هدف و شرح آزمون

فایل‌هایی مانند robots.txt ، sitemap.xml ، فایل‌های Policy و سایر Metadata ممکن است مسیرهای داخلی، Directory ها یا منابعی را که برای عموم قابل مشاهده نیستند افشا کنند.

روش آزمون

فایل‌های Metadata شناخته‌شده و مسیرهای استاندارد مرتبط با Web Server بررسی و محتوای آن‌ها از نظر افشای اطلاعات حساس تحلیل شد.

نتیجه و تحلیل

اطلاعات موجود در Metadata ها منجر به افشای Credential، مسیرهای حساس، فایل‌های Configuration یا منابع مدیریتی نشد و اطلاعات قابل استخراج از آن‌ها در سطحی نبود که بتواند به‌صورت عملی موجب افزایش سطح دسترسی مهاجم شود.

نتیجه: Secure.

Enumerate Applications on Webserver 4.1.4

هدف و شرح آزمون

هدف، شناسایی Application ها، Virtual Directory ها، Sub-Application ها و سرویس‌هایی است که روی Web Server میزبانی می‌شوند.

روش آزمون

مسیرهای مختلف Virtual Path، Application ها، Subdomain ها، Endpoint های شناخته‌شده و Response های HTTP مورد بررسی قرار گرفتند.

نتیجه و تحلیل

Application های قابل دسترس شناسایی و سطح حمله آن‌ها بررسی شد. سرویس یا Application ناشناخته‌ای که بتواند بدون کنترل دسترسی مناسب مورد سوءاستفاده قرار گیرد شناسایی نشد.

Review Webpage Content for Information 4.1.5 Leakage

هدف و شرح آزمون

این آزمون به منظور شناسایی اطلاعات حساس موجود در Source Code، HTML، JavaScript، Comment ها، URL ها و محتوای صفحات انجام می‌شود.

روش آزمون

Source صفحات، JavaScript های Comment، Client-side ها، URL، Metadata ها و Response Body ها بررسی شدند.

نتیجه و تحلیل

Credential، Secret Key، Token، Password، Connection String و سایر اطلاعات حساس در محتوای قابل دسترسی عمومی مشاهده نشد. اطلاعات فنی موجود نیز به گونه‌ای نبود که به تنهایی امکان عبور از کنترل‌های امنیتی را فراهم کند.

نتیجه: Secure.

Identify Application Entry Points 4.1.6

هدف و شرح آزمون

هدف شناسایی تمام نقاط ورود داده به Application است؛ از جمله Query Parameter، POST Body، Header، Cookie، Path Parameter، File Upload و سایر Interface ها.

روش آزمون

Traffic تولیدشده توسط Application های API، فرم‌ها، پارامترها و درخواست‌های HTTP از طریق Proxy و تحلیل دستی بررسی شدند.

نتیجه و تحلیل

نقاط ورود شناسایی و برای آزمون‌های بعدی در نظر گرفته شدند. پارامترهای قابل کنترل توسط کاربر به‌عنوان Input Source مورد ارزیابی امنیتی قرار گرفتند و نقطه ورودی مخفی یا غیرمستندی که منجر به دور زدن کنترل‌های امنیتی شود شناسایی نشد.

نتیجه: **Secure**.

Map Execution Paths Through Application 4.1.7

هدف و شرح آزمون

هدف مشخص کردن مسیرهای مختلف اجرای Application و بررسی امکان رسیدن کاربر به مسیرهایی است که نباید مستقیماً قابل دسترسی باشند.

روش آزمون

Workflowهای مختلف Application، Navigation، API Call و مسیرهای منطقی اجرای عملیات بررسی شدند.

نتیجه و تحلیل

مسیرهای اجرای اصلی Application شناسایی شدند و تلاش برای دسترسی مستقیم به مراحل میانی یا حذف مراحل الزامی Workflow، کنترل‌های امنیتی Application را دور نزد.

نتیجه: **Secure**.

Fingerprint Web Application Framework 4.1.8

هدف و شرح آزمون

هدف شناسایی Framework سمت Server یا Client و بررسی اطلاعات Version و مؤلفه‌های مرتبط با آن است.

روش آزمون

Response Header ها، ساختار Error Response، URL ها، Cookie ها، Source Code و الگوهای اختصاصی Framework بررسی شدند.

نتیجه و تحلیل

Framework مورد استفاده در حد اطلاعات مورد نیاز برای ارزیابی امنیتی شناسایی شد، اما اطلاعات افشاشده منجر به افشای Secret یا فراهم شدن مسیر مستقیم برای Exploitation نگردید.

نتیجه: Secure.

Fingerprint Web Application 4.1.9

هدف و شرح آزمون

هدف تعیین مشخصات Application، قابلیت‌ها، API ها، Authentication Mechanism، فناوری‌های Backend و سایر مؤلفه‌های قابل شناسایی است.

نتیجه و تحلیل

Application Fingerprinting انجام شد و سطح حمله آن مشخص گردید. قابلیت یا Component ناشناخته و آسیب‌پذیری که بتواند بدون Authentication مورد سوءاستفاده قرار گیرد شناسایی نشد.

نتیجه: Secure.

Map Application Architecture 4.1.10

هدف و شرح آزمون

هدف شناسایی ارتباط میان Client، Web Server، Application Server، API، Database و سایر اجزای معماری است.

نتیجه و تحلیل

معماری منطقی Application از طریق تحلیل Traffic و رفتار Endpoint ها بررسی شد. Backend Interface های به صورت مستقیم و بدون کنترل های امنیتی قابل سوءاستفاده در دسترس قرار نگرفته بودند.

نتیجه: Secure.

Configuration and Deployment 4.2 Management Testing

Test Network Infrastructure Configuration 4.2.1

هدف این آزمون شناسایی پورت ها، سرویس ها، Interface های غیرضروری و Configuration های ناامن در سطح Network Infrastructure است.

Port و Service Enumeration انجام شد و سرویس غیرضروری یا قابل بهره برداری که منجر به افزایش سطح حمله Application شود شناسایی نگردید.

نتیجه: Secure.

Test Application Platform Configuration 4.2.2

هدف بررسی Configuration مربوط به Default، Directory Listing، Debug Mode، Web/Application Server، Configuration و سایر تنظیمات امنیتی است.

Application در حالت Debug قابل بهره برداری قرار نداشت و Configuration مشاهده شده امکان دسترسی غیرمجاز به منابع حساس را فراهم نمی کرد.

نتیجه: Secure.

Test File Extensions Handling for Sensitive 4.2.3

Information

هدف بررسی امکان دسترسی به فایل‌هایی با Extension های حساس مانند Configuration، Source Code، Backup و فایل‌های موقت است.

Extension های حساس و مسیرهای محتمل مورد بررسی قرار گرفتند و فایل حاوی Credential، Source Code، Configuration Secret یا داده حساس از طریق Web قابل دریافت نبود.

نتیجه: Secure.

Review Old Backup and Unreferenced Files 4.2.4

هدف شناسایی فایل‌های Old Version، Backup، Temporary و فایل‌های Unreferenced است.

مسیرهای متداول و الگوهای نامگذاری فایل‌های Backup بررسی شدند. فایل حساس یا نسخه قدیمی Application که بتواند اطلاعات داخلی یا Source Code را افشا کند مشاهده نشد.

نتیجه: Secure.

Enumerate Infrastructure and Application Admin Interfaces 4.2.5

هدف شناسایی Interface های مدیریتی مانند Management Console، Admin Panel و Debug Interface است.

مسیرهای مدیریتی شناخته شده و قابل حدس بررسی شدند. Interface مدیریتی قابل سوءاستفاده بدون Authentication مناسب شناسایی نشد.

نتیجه: Secure.

Test HTTP Methods 4.2.6

هدف بررسی فعال بودن HTTP Method های غیرضروری یا خطرناک و امکان سوءاستفاده از Method های متفاوت برای دور زدن Authorization است.

Method های HTTP از جمله GET، POST، PUT، DELETE، OPTIONS و TRACE بررسی شدند. تغییر Method موجب دور زدن کنترل دسترسی یا اجرای عملیات غیرمجاز نشد.

نتیجه: Secure.

Test HTTP Strict Transport Security 4.2.7

هدف HSTS جلوگیری از برقراری ارتباط HTTP و کاهش ریسک Downgrade و Man-in-the-Middle است.

Application در ارتباطات حساس از کانال HTTPS استفاده می‌کند و بررسی انجام‌شده نشان داد مسیرهای حساس از طریق کانال رمزنگاری‌شده قابل دسترسی هستند.

نتیجه: Secure.

Test RIA Cross Domain Policy 4.2.8

هدف بررسی فایل‌هایی مانند crossdomain.xml و clientaccesspolicy.xml و شناسایی Policy های بیش از حد باز است.

Policy های Cross-Domain بررسی شدند و Policy ای که امکان دسترسی غیرمجاز Cross-Domain به منابع حساس Application را فراهم کند شناسایی نشد.

نتیجه: Secure.

Test File Permission 4.2.9

هدف بررسی دسترسی غیرمجاز به فایل‌ها و Directory های Server است.

مسیرهای مختلف و فایل‌های حساس مورد آزمون قرار گرفتند و دسترسی بدون مجوز به منابع محافظت‌شده امکان‌پذیر نبود.

نتیجه: Secure.

Test for Subdomain Takeover 4.2.10

هدف شناسایی Subdomain هایی است که به سرویس خارجی اشاره می کنند اما Resource متناظر در سرویس مقصد حذف شده و امکان Claim شدن آن توسط مهاجم وجود دارد.

DNS Record ها، CNAME ها و سرویس های Third-Party مرتبط بررسی شدند. Subdomain دارای وضعیت Dangling DNS قابل Claim شناسایی نشد.

نتیجه: Secure.

Test Cloud Storage 4.2.11

هدف بررسی Bucket ها و Cloud Storage هایی است که ممکن است به صورت Public در دسترس باشند.

Storage های مرتبط با Application بررسی شدند و دسترسی Anonymous به Object های حساس یا قابلیت Listing/Write غیرمجاز مشاهده نشد.

نتیجه: Secure.

Identity Management Testing 4.3

Test Role Definitions 4.3.1

هدف بررسی تعریف Role ها و اطمینان از تفکیک مناسب سطح دسترسی کاربران است.

Role های موجود و عملیات قابل انجام توسط هر Role بررسی شدند. امکان انجام عملیات خارج از Scope مربوط به Role از طریق تغییر Request یا Parameter مشاهده نشد.

نتیجه: Secure.

Test User Registration Process 4.3.2

هدف بررسی فرآیند ایجاد حساب و کنترل‌هایی است که مانع ثبت‌نام غیرمجاز یا ایجاد Account با وضعیت نامعتبر می‌شوند.

فرآیند Registration بررسی شد و Validation‌های لازم روی اطلاعات ورودی اعمال می‌شد. امکان ایجاد Account با Privilege غیرمجاز یا عبور از مراحل الزامی Registration مشاهده نشد.

نتیجه: Secure.

Test Account Provisioning Process 4.3.3

هدف بررسی نحوه ایجاد و اختصاص Privilege به حساب‌های جدید است.

فرآیند Provisioning بررسی شد و Account جدید با سطح دسترسی بالاتر از مقدار مورد انتظار ایجاد نمی‌شد.

نتیجه: Secure.

Testing for Account Enumeration and Guessable User Account 4.3.4

هدف شناسایی امکان تشخیص معتبر بودن Username از طریق تفاوت Response، Error Message، Status یا Code Timing است.

رفتار Application در برابر Username‌های معتبر و نامعتبر مقایسه شد. تفاوتی که بتواند به‌صورت قابل اتکا برای Enumeration کاربران مورد استفاده قرار گیرد مشاهده نشد.

نتیجه: Secure.

Testing for Weak or Unenforced Username Policy 4.3.5

هدف بررسی امکان استفاده از Username‌های نامعتبر، تکراری یا قابل سوءاستفاده است.

Policy مربوط به Username بررسی شد و Application از ایجاد Username های ناسازگار با قواعد تعریف شده جلوگیری می کرد.

نتیجه: Secure.

Authentication Testing 4.4

Testing for Credentials Transported over an 4.4.1 Encrypted Channel

هدف جلوگیری از ارسال Username و Password از طریق HTTP یا سایر کانال های غیر رمزنگاری شده است.

Authentication Traffic بررسی شد و Credential ها در بستر HTTPS منتقل می شدند. امکان مشاهده Credential ها در ارتباط رمزنگاری نشده وجود نداشت.

نتیجه: Secure.

Testing for Default Credentials 4.4.2

هدف بررسی وجود Credential های پیش فرض یا Credential های شناخته شده است.

Credential های پیش فرض متداول برای Application و Interface های مدیریتی بررسی شدند و Authentication با Credential پیش فرض موفق نبود.

نتیجه: Secure.

Testing for Weak Lock Out Mechanism 4.4.3

هدف بررسی مقاومت Application در برابر Brute Force و Credential Guessing است.

رفتار Authentication در برابر تلاش های متعدد و متوالی بررسی شد. کنترل های امنیتی مربوط به محدودسازی تلاش های Authentication و جلوگیری از سوءاستفاده از فرآیند Login مورد بررسی قرار گرفتند و امکان Brute Force نامحدود و قابل بهره برداری احراز نگردید.

Testing for Bypassing Authentication Schema 4.4.4

هدف بررسی امکان دسترسی به منابع محافظت شده بدون ارائه Credential معتبر است.

Endpoint های محافظت شده مستقیماً، با حذف Token، تغییر Header ها، تغییر Method و Manipulation درخواست مورد آزمون قرار گرفتند. Application در صورت فقدان یا نامعتبر بودن Credential، دسترسی لازم را اعطا نمی کرد.

نتیجه: Secure.

Testing for Vulnerable Remember Password 4.4.5

هدف بررسی امنیت قابلیت Remember Me و مکانیزم نگهداری وضعیت Authentication است.

Token های مرتبط با Remember Password بررسی شدند و اطلاعات حساس به صورت ناامن در Client ذخیره نمی شد. امکان جعل یا Manipulation مکانیزم Remember Password مشاهده نشد.

نتیجه: Secure.

Testing for Browser Cache Weaknesses 4.4.6

هدف جلوگیری از ذخیره شدن اطلاعات حساس Authentication و داده های محرمانه در Browser Cache است.

Response های صفحات و Endpoint های حساس بررسی شدند و اطلاعات Authentication یا داده حساس به گونه ای در Cache ذخیره نمی شد که پس از Logout یا دسترسی فیزیکی به Browser قابل بازیابی باشد.

نتیجه: Secure.

Testing for Weak Password Policy 4.4.7

هدف بررسی حداقل طول، Complexity و محدودیت‌های مربوط به Password است.

Password Policy بررسی شد و Application از Password های بسیار ضعیف و نامتناسب با الزامات امنیتی جلوگیری می‌کرد.

نتیجه: Secure.

Testing for Weak Security Question Answer 4.4.8

هدف بررسی قابلیت سوءاستفاده از Security Question برای بازیابی Account است.

در Application مکانیزم Security Question قابل بهره‌برداری برای بازیابی غیرمجاز حساب مشاهده نشد و مسیر جایگزینی که بتواند Authentication را تضعیف کند شناسایی نگردید.

نتیجه: Secure / Not Applicable.

Testing for Weak Password Change or Reset 4.4.9 Functionalities

هدف بررسی امکان تغییر یا Reset Password بدون Authentication مناسب، بدون Password قبلی یا با Manipulation Token است.

فرآیند Password Change/Reset بررسی شد و تغییر Credential نیازمند کنترل‌های Authentication و Authorization مربوطه بود. Manipulation پارامترها و Token ها منجر به تغییر Password حساب دیگر نشد.

نتیجه: Secure.

Testing for Weaker Authentication in 4.4.10 Alternative Channel

هدف بررسی این است که آیا یک Channel جایگزین مانند API Endpoint، Mobile API، یا Interface دیگر Authentication ضعیف‌تری دارد یا خیر.

Channel‌های قابل دسترس مقایسه شدند و مسیر جایگزینی که امکان عبور از کنترل‌های Authentication اصلی را فراهم کند مشاهده نشد.

نتیجه: Secure.

Authorization Testing 4.5

Testing Directory Traversal / File Include 4.5.1

هدف بررسی امکان دسترسی به فایل‌های خارج از مسیر مجاز با استفاده از Path Traversal و File Inclusion است.

پارامترهای مرتبط با Path و File با ورودی‌های Traversal و مسیرهای خارج از محدوده مورد آزمون قرار گرفتند. Application دسترسی غیرمجاز به فایل‌های خارج از Context مجاز را اعطا نکرد.

نتیجه: Secure.

Testing for Bypassing Authorization Schema 4.5.2

هدف بررسی امکان عبور از Authorization با تغییر Header، Parameter، Method، یا URL، Token است.

درخواست‌های مربوط به منابع محافظت‌شده با تغییر مستقیم Identifierها و ساختار Request مورد آزمون قرار گرفتند. Server-side Authorization همچنان اعمال می‌شد و تغییر Client-side Request موجب اعطای دسترسی نشد.

نتیجه: Secure.

Testing for Privilege Escalation 4.5.3

هدف شناسایی امکان ارتقای سطح دسترسی از User به Role های بالاتر است. عملیات Administrative و Privileged با Account دارای سطح دسترسی پایین تر مورد آزمون قرار گرفتند. تغییر Role، Parameter یا Endpoint منجر به اجرای عملیات با Privilege بالاتر نشد.

نتیجه: Secure.

Testing for Insecure Direct Object References 4.5.4

هدف بررسی امکان دسترسی کاربر به Object متعلق به کاربر دیگر از طریق تغییر مستقیم Identifier است. شناسه های Object ها در Request ها تغییر داده شدند و Access Control سمت Server بررسی شد. Application در صورت عدم تعلق Object به User، دسترسی مناسب را اعطا نمی کرد.

نتیجه: IDOR – Secure مشاهده نشد.

Session Management Testing 4.6

Testing for Session Management Schema 4.6.1

هدف بررسی نحوه ایجاد، نگهداری و اعتبارسنجی Session است. Session Token ها، Lifecycle، نحوه صدور Token و ارتباط آن با User بررسی شدند. Token معتبر بدون دستکاری قابل استفاده بود و تغییرات غیرمجاز در Session منجر به جعل هویت نشد.

نتیجه: Secure.

Testing for Cookies Attributes 4.6.2

هدف بررسی Secure، HttpOnly، SameSite و سایر Attribute های امنیتی Cookie است.

Cookie های Application بررسی شدند. Cookie های حساس از نظر محدودیت دسترسی Client-side و ارسال در Context های Cross-Site ارزیابی شدند و Configuration مشاهده شده امکان سوءاستفاده مستقیم از Session را فراهم نمی کرد.

نتیجه: Secure.

Testing for Session Fixation 4.6.3

هدف بررسی امکان تعیین Session توسط مهاجم پیش از Authentication و سپس استفاده از همان Session پس از Login است.

Session قبل و بعد از Authentication مقایسه شد و امکان تثبیت Session توسط مهاجم و تبدیل آن به Session معتبر کاربر مشاهده نشد.

نتیجه: Secure.

Testing for Exposed Session Variables 4.6.4

هدف بررسی افشای Session Identifier یا سایر Session Variable های حساس در Log، HTML، URL، قابل دسترس، Header یا Client Storage است.

Session Information در محل ناامن یا به صورت قابل سوءاستفاده افشا نشد.

نتیجه: Secure.

Testing for Cross-Site Request Forgery 4.6.5

هدف بررسی امکان اجرای عملیات حساس توسط مهاجم از طریق درخواست Cross-Site و بدون رضایت کاربر است.

Endpoint های حساس و State-Changing Request ها مورد بررسی قرار گرفتند. Context مربوط به Authentication و کنترل های Application مانع اجرای غیرمجاز عملیات از طریق Cross-Site Request شد.

نتیجه: Secure.

Testing for Logout Functionality 4.6.6

هدف اطمینان از Invalid شدن Session پس از Logout است.

پس از Logout، استفاده مجدد از Session/Token قبلی مورد آزمون قرار گرفت. Session معتبر پس از خروج قابلیت انجام عملیات محافظت شده را نداشت.

نتیجه: Secure.

Testing Session Timeout 4.6.7

هدف بررسی Expiration Session پس از مدت زمان مشخص و جلوگیری از Session های دائمی است.

Lifecycle مربوط به Session بررسی شد و Session پس از پایان مدت اعتبار قابل استفاده برای دسترسی به منابع محافظت شده نبود.

نتیجه: Secure.

Testing for Session Puzzling 4.6.8

هدف بررسی امکان استفاده از Session ایجاد شده برای یک Context یا Functionality در Context دیگر است.

Session های ایجاد شده در سناریوهای مختلف بررسی شدند و امکان انتقال Session بین Context های متفاوت و دستیابی به Privilege غیرمرتبط مشاهده نشد.

نتیجه: Secure.

Testing for Session Hijacking 4.6.9

هدف بررسی امکان سرقت و استفاده غیرمجاز از Session Token است.

Session Token ها از نظر Exposure، Predictability، و امکان Replay بررسی شدند. امکان استخراج یا جعل Session معتبر از طریق اطلاعات در دسترس Application مشاهده نشد.

Input Validation Testing 4.7

Testing for Reflected Cross-Site Scripting 4.7.1

هدف شناسایی امکان انعکاس ورودی مهاجم در Response و اجرای JavaScript در Browser قربانی است. پارامترهای ورودی با Payloadهای XSS و Contextهای مختلف HTML/JavaScript مورد آزمون قرار گرفتند. ورودی‌ها به صورت Executable در Response قرار نگرفتند و Script قابل اجرا ایجاد نشد.

نتیجه: Secure.

Testing for Stored Cross-Site Scripting 4.7.2

هدف شناسایی ذخیره شدن Payload مخرب و اجرای آن هنگام مشاهده داده توسط کاربر دیگر است. فیلدهای قابل ذخیره‌سازی با Payloadهای XSS بررسی شدند. داده ذخیره‌شده بدون ایجاد Execution Context خطرناک نمایش داده می‌شد و اجرای Script در Client مشاهده نشد.

نتیجه: Secure.

Testing for HTTP Verb Tampering 4.7.3

هدف بررسی امکان تغییر HTTP Method برای عبور از Validation یا Authorization است. Endpointها با Methodهای متفاوت مورد آزمون قرار گرفتند. تغییر Method موجب اجرای عملیات غیرمجاز یا دور زدن کنترل‌های Application نشد.

نتیجه: Secure.

Testing for HTTP Parameter Pollution 4.7.4

هدف بررسی امکان ارسال چند مقدار برای یک Parameter و ایجاد اختلاف در تفسیر Client و Server است. پارامترها به صورت Duplicate ارسال شدند و رفتار Application بررسی شد. اختلاف تفسیری قابل بهره‌برداری که منجر به دور زدن Validation یا Authorization شود مشاهده نشد.

نتیجه: Secure.

Testing for SQL Injection 4.7.5

هدف کلی این مجموعه آزمون‌ها شناسایی امکان تزریق دستورات SQL در ورودی‌های Application و تغییر منطق Queryهای Backend است.

پارامترهای ورودی با Payloadهای Union-Based، Boolean-Based، Error-Based و Time-Based مورد بررسی قرار گرفتند. تغییر ورودی‌ها موجب ایجاد خطای Database، تغییر Dataset یا Delay قابل تکرار ناشی از اجرای Query تزریقی نشد.

نتیجه کلی: Secure – SQL Injection شناسایی نشد.

Oracle 4.7.5.1

ورودی‌های قابل کنترل با الگوهای متناسب با Oracle SQL بررسی شدند و رفتار قابل انتساب به Oracle SQL Injection مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

MySQL 4.7.5.2

Payloadهای متناسب با MySQL و رفتارهای Error/Boolean/Time-Based بررسی شدند و امکان تغییر Query مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

SQL Server 4.7.5.3

ورودی‌ها با Syntaxهای متناسب با Microsoft SQL Server مورد بررسی قرار گرفتند و Database Error یا رفتار قابل بهره‌برداری مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

PostgreSQL 4.7.5.4

ورودی‌ها با Payload های PostgreSQL مورد آزمون قرار گرفتند. امکان اجرای SQL خارج از Context مورد انتظار مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

MS Access 4.7.5.5

الگوهای Injection متناسب با Access بررسی شدند و رفتار آسیب‌پذیر مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

NoSQL Injection 4.7.5.6

پارامترهای مرتبط با Backend و Object-based Input از نظر امکان تغییر Query یا Operator های NoSQL بررسی شدند. امکان Manipulation Query مشاهده نشد.

نتیجه: Secure.

ORM Injection 4.7.5.7

Input ها از نظر عبور از لایه ORM و ایجاد Query Manipulation مورد آزمون قرار گرفتند. رفتار قابل بهره‌برداری مشاهده نشد.

نتیجه: Secure.

Client-side SQL Injection 4.7.5.8

Application از نظر پردازش SQL-like Input در Client و انتقال آن به Backend بررسی شد و مسیر قابل بهره‌برداری برای SQL Injection سمت Client شناسایی نشد.

نتیجه: Secure.

Testing for LDAP Injection 4.7.6

هدف بررسی امکان تغییر LDAP Query از طریق ورودی کاربر است.

پارامترهای مرتبط با Authentication و Search با LDAP Meta-characterها بررسی شدند و امکان تغییر Query یا دسترسی غیرمجاز مشاهده نشد.

نتیجه: Secure.

Testing for XML Injection 4.7.7

هدف بررسی امکان تزریق داده یا ساختار XML مخرب در Application است.

XML Inputهای قابل کنترل بررسی شدند و امکان تغییر ساختار مورد انتظار یا تزریق داده‌ای که منجر به اجرای عملیات غیرمجاز شود مشاهده نشد.

نتیجه: Secure.

Testing for SSI Injection 4.7.8

هدف بررسی امکان تزریق Server-Side Include Directive در محتوای پردازش‌شده توسط Server است.

Inputها با الگوهای SSI بررسی شدند و Server هیچ Directive تزریق‌شده‌ای را اجرا نکرد.

نتیجه: Secure.

Testing for XPath Injection 4.7.9

هدف بررسی امکان تغییر XPath Query از طریق Input کاربر است.

پارامترهای مرتبط با Search/Lookup مورد آزمون قرار گرفتند و امکان تغییر منطق XPath Query مشاهده نشد.

نتیجه: Secure.

Testing for IMAP/SMTP Injection 4.7.10

هدف بررسی امکان تزریق دستورات SMTP/IMAP از طریق Inputهایی مانند Email و Header است.

ورودی‌های Email با Line Feed، Carriage Return و سایر کاراکترهای کنترل مورد آزمون قرار گرفتند. امکان ایجاد Header یا Command غیرمجاز مشاهده نشد.

نتیجه: Secure.

Testing for Code Injection 4.7.11

هدف کلی بررسی امکان قرار گرفتن Input کاربر در Contextی است که Server آن را به‌عنوان Code تفسیر و اجرا کند.

ورودی‌ها در Contextهای مختلف مورد بررسی قرار گرفتند و امکان اجرای Code کنترل‌شده توسط کاربر مشاهده نشد.

نتیجه: Secure.

Local File Inclusion 4.7.11.1

پارامترهای File/Path با مسیرهای Local مورد آزمون قرار گرفتند. امکان خواندن فایل‌های Local خارج از محدوده مجاز مشاهده نشد.

نتیجه: Secure.

Remote File Inclusion 4.7.11.2

Application از نظر دریافت و پردازش Resource خارجی از طریق پارامترهای قابل کنترل بررسی شد و امکان Include کردن Resource خارجی مشاهده نشد.

نتیجه: Secure.

Testing for Command Injection 4.7.12

هدف بررسی امکان اجرای Command سیستم‌عامل از طریق ورودی Application است.

Inputها با Metacharacterهای سیستم‌عامل و الگوهای Command Injection بررسی شدند. نشانه‌ای از اجرای Command، تغییر رفتار Server یا Response Time ناشی از Command Execution مشاهده نشد.

نتیجه: Secure.

Testing for Format String Injection 4.7.13

هدف بررسی امکان سوءاستفاده از Format String در پردازش Input است.

Input‌های دارای Format Specifier مورد آزمون قرار گرفتند و Crash، Memory Disclosure یا تغییر رفتار Application مشاهده نشد.

نتیجه: Secure.

Testing for Incubated Vulnerability 4.7.14

هدف شناسایی آسیب‌پذیری‌هایی است که Payload آن‌ها در یک مرحله ذخیره شده و در مرحله دیگری Trigger می‌شود.

داده‌های ذخیره‌شده در مراحل مختلف Application مجدداً بررسی شدند و هیچ Payload ذخیره‌شده‌ای که در Context دیگری منجر به اجرای رفتار مخرب شود مشاهده نشد.

نتیجه: Secure.

Testing for HTTP Splitting / Smuggling 4.7.15

هدف بررسی امکان Manipulation در HTTP Message Parsing و ایجاد اختلاف میان Proxy، Web Server و Backend است.

Request‌ها از نظر Header Manipulation، Content-Length/Transfer-Encoding و رفتارهای غیرعادی Parsing بررسی شدند. اختلاف قابل بهره‌برداری میان اجزای HTTP Stack مشاهده نشد.

نتیجه: Secure.

Testing for HTTP Incoming Requests 4.7.16

هدف بررسی قابلیت‌هایی است که Application را وادار به پردازش یا اعتماد به HTTP Request‌های ورودی غیرمنتظره می‌کنند.

Header ها و Request های غیرعادی بررسی شدند و Application در برابر ورودی های غیرمنتظره رفتار کنترل شده ای داشت.

نتیجه: Secure.

Testing for Host Header Injection 4.7.17

هدف بررسی امکان تغییر Host Header برای ایجاد Password Reset Link، Redirect، Cache Poisoning یا سایر رفتارهای امنیتی نامناسب است.

Host Header با مقادیر غیرمعتبر Manipulate شد. Application از Host کنترل شده توسط مهاجم برای ایجاد رفتار حساس استفاده نکرد.

نتیجه: Secure.

Testing for Server-Side Template Injection 4.7.18

هدف بررسی امکان قرار گرفتن User Input در Template Server-side و اجرای Expression یا Code است.

Input های Template Expression در نقاط ورودی بررسی شدند و هیچ نشانه ای از Evaluation سمت Server مشاهده نشد.

نتیجه: Secure.

Testing for Server-Side Request Forgery 4.7.19

هدف بررسی امکان مجبور کردن Server به ارسال Request به مقصدی است که مهاجم تعیین می کند، مانند Internal Network، localhost یا سرویس های داخلی.

پارامترهایی که احتمالاً می توانستند مقصد Request را تحت کنترل کاربر قرار دهند بررسی شدند. امکان ارسال Request غیرمجاز به منابع داخلی یا مقصد خارجی دلخواه مشاهده نشد.

نتیجه: Secure.

Testing for Error Handling 4.8

Testing for Improper Error Handling 4.8.1

هدف بررسی این است که Errorهای Application اطلاعات حساس یا مسیر حمله در اختیار مهاجم قرار ندهند.

Requestهای نامعتبر، پارامترهای اشتباه و شرایط Exception مورد آزمون قرار گرفتند. Application به صورت کنترل شده Error Response تولید کرد و Error قابل بهره برداری یا اطلاعات حساس در اختیار Client قرار نگرفت.

نتیجه: Secure.

Testing for Stack Traces 4.8.2

هدف بررسی افشای Stack Trace، Source Path، Class Name، Framework Version یا اطلاعات Backend است.

در Responseهای خطا Stack Trace قابل بهره برداری یا اطلاعات حساس داخلی مشاهده نشد.

نتیجه: Secure.

Testing for Weak Cryptography 4.9

Testing for Weak Transport Layer Security 4.9.1

هدف بررسی Certificate، Cipher Suite، TLS Version و Configuration مربوط به Transport Security است.

ارتباطات HTTPS بررسی شدند و استفاده از Protocolها و Cipherهای ناامن که امکان کاهش معنادار سطح امنیت ارتباط را فراهم کنند مشاهده نشد.

نتیجه: Secure.

Testing for Padding Oracle 4.9.2

هدف بررسی امکان استخراج Plaintext یا Manipulation داده‌های رمزنگاری‌شده از طریق تفاوت در خطاهای Padding است.

Ciphertext‌های Manipulate شده مورد آزمون قرار گرفتند و Response قابل استفاده برای استخراج اطلاعات رمزنگاری‌شده یا اجرای Padding Oracle مشاهده نشد.

نتیجه: Secure.

Testing for Sensitive Information Sent via 4.9.3 Unencrypted Channels

هدف جلوگیری از انتقال اطلاعات حساس از طریق HTTP یا سایر کانال‌های بدون رمزنگاری است.

Authentication و داده‌های حساس از طریق کانال رمزنگاری‌شده منتقل می‌شدند و ارسال قابل بهره‌برداری اطلاعات حساس از طریق کانال Unencrypted مشاهده نشد.

نتیجه: Secure.

Testing for Weak Encryption 4.9.4

هدف شناسایی استفاده از الگوریتم‌های Cryptographic ضعیف یا روش‌های رمزنگاری نامناسب است.

مکانیزم‌های رمزنگاری قابل مشاهده Application بررسی شدند و الگوریتم یا روش رمزنگاری شناخته‌شده‌ای که بتواند در شرایط آزمون موجب افشای داده حساس شود مشاهده نشد.

نتیجه: Secure.

Business Logic Testing 4.10

Introduction to Business Logic 4.10.0

آزمون Business Logic با هدف بررسی صحیح بودن محدودیت‌ها و قواعدی انجام می‌شود که صرفاً از طریق Syntax یا تکنولوژی قابل تشخیص نیستند.

در این بخش Workflow‌های Application از دیدگاه مهاجم بررسی شدند.

Test Business Logic Data Validation 4.10.1

هدف بررسی این است که داده‌های ورودی از نظر منطق کسب‌وکار نیز معتبر باشند.

مقادیر خارج از محدوده، مقادیر منفی، Empty، Null، مقادیر بسیار بزرگ و ترکیبات غیرمنتظره بررسی شدند. Application از پردازش داده‌هایی که منجر به نقض قواعد کسب‌وکار شوند جلوگیری می‌کند.

نتیجه: Secure.

Test Ability to Forge Requests 4.10.2

هدف بررسی امکان ساخت مستقیم Request‌هایی است که UI اجازه ایجاد آنها را نمی‌دهد.

Request‌ها به صورت دستی ایجاد و Manipulate شدند. Server-side Validation و Authorization مانع اجرای Request‌های غیرمجاز شدند.

نتیجه: Secure.

Test Integrity Checks 4.10.3

هدف بررسی صحت و تمامیت داده‌های حساس و جلوگیری از Manipulation آنها است.

پارامترهای حساس، Identifierها و داده‌های مرتبط با State مورد Manipulation قرار گرفتند. تغییر مستقیم Client-side Data باعث ایجاد وضعیت غیرمجاز در Server نشد.

Test for Process Timing 4.10.4

هدف بررسی Race Condition و امکان سوءاستفاده از Timing در فرآیندهای حساس است.

Requestهای همزمان و تکراری برای عملیات حساس ارسال شدند و وضعیت ناسازگار، Duplicate Transaction یا دور زدن کنترل‌های منطقی مشاهده نشد.

نتیجه: Secure.

Test Number of Times a Function Can Be Used Limits 4.10.5

هدف بررسی محدودیت تعداد دفعات اجرای عملیات حساس است.

عملیات محدودشده به صورت متوالی تکرار شدند و Application از اجرای غیرمحدود عملیات در مواردی که نیازمند محدودیت بود جلوگیری می‌کرد.

نتیجه: Secure.

Testing for Circumvention of Work Flows 4.10.6

هدف بررسی امکان حذف، جابه‌جایی یا تکرار مراحل Workflow است.

مراحل Workflow مستقیماً و خارج از ترتیب مورد انتظار فراخوانی شدند. Server-side State Validation مانع عبور از مراحل الزامی شد.

نتیجه: Secure.

Test Defenses Against Application Misuse 4.10.7

هدف بررسی امکان استفاده از قابلیت‌های قانونی Application برای اهداف غیرمنتظره و مخرب است. قابلیت‌های مختلف از دیدگاه مهاجم بررسی شدند و امکان سوءاستفاده عملی از Functionality‌های موجود برای دور زدن کنترل‌های امنیتی مشاهده نشد.

نتیجه: Secure.

Test Upload of Unexpected File Types 4.10.8

هدف بررسی امکان Upload فایل‌هایی با Extension یا MIME Type غیرمجاز است. File Upload با Extension‌ها و Content Type‌های غیرمنتظره مورد آزمون قرار گرفت. Application از پذیرش و پردازش فایل‌هایی که خارج از محدوده مجاز بودند جلوگیری می‌کرد.

نتیجه: Secure.

Test Upload of Malicious Files 4.10.9

هدف بررسی امکان Upload فایل مخرب و سپس اجرای آن روی Server یا Client است. فایل‌های حاوی محتوای غیرمجاز و Payload‌های مختلف مورد آزمون قرار گرفتند. فایل Upload شده به گونه‌ای در دسترس قرار نمی‌گرفت که بتواند به عنوان Code/Script اجرایی مورد استفاده قرار گیرد.

نتیجه: Secure.

Client-side Testing 4.11

Testing for DOM-Based Cross-Site Scripting 4.11.1

هدف شناسایی مسیرهایی است که Input کاربر در Client-side JavaScript مستقیماً وارد Sink‌های خطرناک می‌شود.

Source و Sink های JavaScript و رفتار DOM در برابر ورودی‌های کنترل‌شده بررسی شدند. مسیر قابل بهره‌برداری برای اجرای JavaScript از طریق DOM مشاهده نشد.

نتیجه: Secure.

Testing for JavaScript Execution 4.11.2

هدف بررسی امکان تزریق یا اجرای JavaScript غیرمجاز در Context Application است.

Input های مختلف در Context های Client-side بررسی شدند و امکان اجرای Code کنترل‌شده توسط مهاجم مشاهده نشد.

نتیجه: Secure.

Testing for HTML Injection 4.11.3

هدف بررسی امکان قرار دادن HTML دلخواه در صفحات Application است.

ورودی‌های HTML در Context های مختلف بررسی شدند و Application مانع ایجاد Markup قابل سوءاستفاده در صفحات شد.

نتیجه: Secure.

Testing for Client-side URL Redirect 4.11.4

هدف بررسی امکان Redirect کردن کاربر به URL تحت کنترل مهاجم است.

پارامترهای Redirect و URL Manipulation بررسی شدند. امکان ایجاد Redirect ناخواسته به مقصد خارجی تحت کنترل مهاجم مشاهده نشد.

نتیجه: Secure.

Testing for CSS Injection 4.11.5

هدف بررسی امکان تزریق CSS و تغییر رفتار یا ظاهر Application به صورت مخرب است.

Input های مرتبط با Style و CSS مورد آزمون قرار گرفتند و امکان تزریق CSS قابل بهره برداری مشاهده نشد.

نتیجه: Secure.

Testing for Client-side Resource Manipulation 4.11.6

هدف بررسی امکان تغییر Resource هایی است که Client بارگذاری می کند، مانند Image، CSS، JavaScript یا سایر منابع.

پارامترهای Resource و URL های قابل کنترل بررسی شدند، امکان جایگزین کردن Resource حساس با منبع مهاجم و اجرای آن مشاهده نشد.

نتیجه: Secure.

Testing Cross Origin Resource Sharing 4.11.7

هدف بررسی CORS Configuration و مشخص کردن این موضوع است که آیا Origin غیرمجاز قادر به ارسال Request و دریافت Response های حساس است یا خیر.

Origin های مختلف، شامل Origin های غیرمجاز و Cross-Origin Request های مختلف، مورد آزمون قرار گرفتند. Application در برابر Origin های غیرمجاز Response حساس را در اختیار JavaScript آن Origin قرار نمی داد. همچنین ترکیب CORS با Credential های حساس منجر به دسترسی Cross-Origin غیرمجاز نشد.

نتیجه: Secure – CORS Misconfiguration قابل بهره برداری مشاهده نشد.

Testing for Cross Site Flashing 4.11.8

هدف بررسی قابلیت های قدیمی Flash و امکان سوءاستفاده از Cross-Domain Policy در محیط های دارای Flash است.

Application وابستگی قابل بهره‌برداری به Flash یا فایل SWF دارای Policy نامن نداشت.

نتیجه: Secure / Not Applicable.

Testing for Clickjacking 4.11.9

هدف بررسی امکان قرار دادن Application داخل Frame مهاجم و فریب کاربر برای انجام عملیات ناخواسته است.

Application از نظر Frame Embedding و Headerهای مرتبط با Clickjacking بررسی شد. امکان قرار دادن صفحات حساس در یک Context مهاجم به‌گونه‌ای که منجر به اجرای عملیات ناخواسته شود مشاهده نشد.

نتیجه: Secure.

Testing WebSockets 4.11.10

هدف بررسی امنیت Message Handling و WebSocket Connection، Origin Validation، Authentication است.

در صورت وجود WebSocket، Connection و Messageهای آن از نظر Authentication، Authorization و Origin مورد بررسی قرار گرفتند. دسترسی غیرمجاز یا امکان ارسال Message خارج از سطح دسترسی کاربر مشاهده نشد.

نتیجه: Secure / در صورت عدم استفاده از WebSocket: Not Applicable.

Testing Web Messaging 4.11.11

هدف بررسی امنیت postMessage و جلوگیری از دریافت Message از Originهای غیرمجاز یا پردازش داده بدون Validation است.

Message Handling سمت Client بررسی شد و Origin و داده‌های دریافتی به‌گونه‌ای پردازش نمی‌شدند که امکان اجرای عملیات حساس از یک Origin غیرقابل اعتماد ایجاد شود.

نتیجه: Secure.

Testing Browser Storage 4.11.12

هدف بررسی ذخیره‌سازی اطلاعات حساس در Local Storage، Session Storage، IndexedDB و سایر مکانیزم‌های Browser Storage است.

Storage‌های سمت Client بررسی شدند. اطلاعاتی که بتواند منجر به سرقت مستقیم Credential یا Session شود در محل ناامن ذخیره نشده بود.

نتیجه: Secure.

Testing for Cross Site Script Inclusion 4.11.13

هدف بررسی امکان بارگذاری JavaScript از منابع Cross-Origin کنترل‌شده توسط مهاجم و سوءاستفاده از اطلاعات Application است.

Resource‌های JavaScript و نحوه بارگذاری آنها بررسی شدند. امکان استفاده از Script Inclusion برای استخراج اطلاعات حساس یا اجرای JavaScript کنترل‌شده توسط مهاجم مشاهده نشد.

نتیجه: Secure.

جمع‌بندی نهایی

بر اساس آزمون‌های انجام‌شده مطابق با چارچوب **OWASP Web Security Testing Guide v4.2**، لایه‌های مختلف امنیتی Application شامل Information Gathering، Configuration and Deployment، Identity Management، Authentication، Authorization، Session Management، Input Validation، Error Handling، Business Logic، Cryptography و Client-side Security مورد ارزیابی قرار گرفتند.

در جریان ارزیابی، تلاش شد علاوه بر بررسی رفتار عادی Application، سناریوهای سوءاستفاده شامل **Request Manipulation، Parameter Tampering، Authentication Bypass، Authorization Bypass، Session Manipulation، Injection، File Manipulation، Cross-Origin Attack، Business Logic Abuse و Client-side Attack** نیز بررسی شوند.

نتایج آزمون‌ها نشان داد که در محدوده و شرایط ارزیابی انجام‌شده، آسیب‌پذیری امنیتی قابل بهره‌برداری که بتواند منجر به دسترسی غیرمجاز، افشای اطلاعات حساس، اجرای کد، دور زدن مکانیزم‌های Authentication/Authorization یا نقض یکپارچگی داده‌ها شود شناسایی نگردید.

با توجه به نتایج حاصل، Application از منظر آزمون‌های مورد بررسی در وضعیت مناسب امنیتی قرار دارد. با این حال، امنیت Application یک فرآیند مستمر بوده و پیشنهاد می‌شود آزمون‌های امنیتی پس از تغییرات مهم در Application، Infrastructure، Authentication Mechanism، API ها و Third-Party Components مجدداً انجام شوند.

نتیجه نهایی ارزیابی:

No Exploitable Vulnerability Identified Within the Tested Scope

4. Web Application Security Testing

4.0 مقدمه و اهداف

ارزیابی امنیتی وب اپلیکیشن با هدف شناسایی آسیب‌پذیری‌های امنیتی، ضعف‌های پیکربندی، خطاهای پیاده‌سازی، ضعف‌های کنترل دسترسی، مشکلات مربوط به مدیریت نشست و احراز هویت، Injection Vulnerability ها، آسیب‌پذیری‌های سمت Client و همچنین ضعف‌های ناشی از منطق کسب‌وکار انجام شده است.

چارچوب اصلی مورد استفاده در این ارزیابی **OWASP Web Security Testing Guide (WSTG) v4.2** بوده است. در این فرآیند، Application از منظر یک مهاجم خارجی مورد بررسی قرار گرفته و تلاش شده است سطح حمله قابل دسترس از طریق API، HTTP/HTTPS، پارامترهای ورودی، Header ها، Cookie ها، فایل‌های قابل دسترسی، فرآیندهای Authentication و Authorization و قابلیت‌های Client-side به صورت جامع مورد ارزیابی قرار گیرد.

آزمون‌ها صرفاً به بررسی رفتار عادی Application محدود نبوده و در موارد مقتضی شامل موارد زیر نیز بوده‌اند:

- Manipulation پارامترهای HTTP
- تغییر HTTP Method
- حذف یا تغییر Authentication Token
- تغییر Identifier ها
- بررسی دسترسی مستقیم به Endpoint ها
- بررسی Response های خطا
- بررسی رفتار Application در مقابل Input های غیرمنتظره
- بررسی Session و Cookie
- بررسی Cross-Origin Behavior
- بررسی File Upload

- بررسی فرآیندهای حساس Business Logic
- بررسی رفتار Application در مقابل Request های ساختگی و خارج از مسیر UI

بر اساس نتایج آزمون های انجام شده، آسیب پذیری قابل بهره برداری در محدوده تست شناسایی نشد.

Information Gathering 4.1

Conduct Search Engine Discovery 4.1.1 Reconnaissance for Information Leakage

هدف و شرح آزمون

هدف از این آزمون شناسایی اطلاعاتی است که به صورت ناخواسته توسط Search Engine ها Index شده و می تواند اطلاعاتی درباره ساختار Application، زیرساخت، کاربران، فایل های حساس یا Interface های داخلی در اختیار مهاجم قرار دهد.

نمونه اطلاعاتی که در این آزمون مورد توجه قرار می گیرند عبارت اند از:

- صفحات Administrative
- فایل های Configuration
- Backup File ها
- Source Code
- مستندات داخلی
- API Documentation
- فایل های حاوی Credential
- اطلاعات مربوط به کاربران
- Error Message های حساس
- Directory های غیرمستند

روش آزمون

دامنه Application و منابع مرتبط با آن از طریق Search Engine Reconnaissance بررسی شدند. Query های مختلف با هدف شناسایی صفحات Index شده، فایل های حساس و منابعی که معمولاً نباید در نتایج جستجو ظاهر شوند مورد استفاده قرار گرفتند.

علاوه بر صفحات اصلی، نتایج مربوط به Extension های حساس، مسیرهای مدیریتی، فایل های Configuration و Backup نیز بررسی شدند.

نتیجه و تحلیل

در نتایج قابل دسترس از Search Engine ها، اطلاعات حساسی که بتواند مستقیماً منجر به Authentication Bypass، افشای Credential، دسترسی به Source Code یا دسترسی به منابع داخلی شود مشاهده نشد. همچنین فایل یا صفحه ای که صرفاً به دلیل Index شدن توسط Search Engine در اختیار مهاجم قرار گرفته باشد و در حالت عادی نباید قابل دسترسی باشد شناسایی نشد.

بنابراین Search Engine Indexing در محدوده آزمون، موجب افزایش قابل توجه Attack Surface نشده است.

نتیجه: Secure – آسیب پذیری شناسایی نشد.

Fingerprint Web Server 4.1.2

هدف و شرح آزمون

هدف از Web Server Fingerprinting شناسایی نوع، محصول و در صورت امکان Version وب سرور است. افشای Version دقیق Web Server می تواند به مهاجم کمک کند تا آسیب پذیری های شناخته شده همان Version را شناسایی و حمله خود را متناسب با آن طراحی کند.

روش آزمون

برای Fingerprinting، موارد زیر مورد بررسی قرار گرفتند:

- HTTP Response Header ها
- Server Banner
- Error Page ها
- Response های HTTP Method های مختلف
- ساختار Response
- رفتار Web Server در مقابل Request های نامعتبر
- الگوهای اختصاصی Web Server

نتیجه و تحلیل

بررسی Response ها نشان داد اطلاعات فنی قابل مشاهده Application در سطحی نیست که به تنهایی امکان Exploitation یک Web Server آسیب پذیر را فراهم کند.

همچنین Version دقیق و قابل سوءاستفاده ای که بتوان بر اساس آن یک CVE مشخص را به Application نسبت داد، مشاهده نشد.

در نتیجه، Fingerprinting انجام شده منجر به شناسایی ضعف امنیتی قابل بهره برداری نشد.

نتیجه: Secure – آسیب پذیری قابل بهره برداری شناسایی نشد.

Review Webserver Metafiles for Information 4.1.3 Leakage

هدف و شرح آزمون

فایل هایی مانند robots.txt و sitemap.xml و سایر Metadata های Web Server ممکن است اطلاعاتی درباره مسیرهای حساس، صفحات مدیریتی یا ساختار داخلی Application ارائه کنند.

روش آزمون

فایل های Metadata شناخته شده و مسیرهای استاندارد مرتبط با Web Server بررسی شدند.

محتوای این فایل ها از نظر موارد زیر تحلیل شد:

- مسیرهای Administrative
- Directory های حساس
- فایل های Backup
- Endpoint های داخلی
- مسیرهای غیرقابل دسترسی از UI
- اطلاعات مربوط به Infrastructure

نتیجه و تحلیل

Metadata های قابل دسترسی حاوی اطلاعاتی نبودند که امکان دسترسی غیرمجاز به منابع حساس را فراهم کند.

همچنین مسیر یا Endpoint حساسی که صرفاً از طریق این فایل‌ها افشا شده باشد و بدون کنترل دسترسی مناسب قابل استفاده باشد مشاهده نشد.

نتیجه: Secure.

Enumerate Applications on Webserver 4.1.4

هدف و شرح آزمون

هدف این آزمون شناسایی Application ها، Virtual Directory ها، Sub-Application ها و سرویس‌های مختلفی است که روی Web Server در دسترس هستند.

وجود Application های قدیمی، آزمایشی یا فراموش شده می‌تواند باعث ایجاد Attack Surface اضافی شود.

روش آزمون

مسیرهای مختلف Application، Virtual Directory ها، Endpoint های شناخته شده، مسیرهای مدیریتی و منابع قابل دسترسی بررسی شدند.

Response های HTTP از نظر:

- Status Code
- Redirect
- Response Size
- Technology Signature
- Authentication Requirement

مقایسه شدند.

نتیجه و تحلیل

Application های قابل دسترسی شناسایی و سطح حمله آن‌ها بررسی شد.

Application یا Interface ناشناخته‌ای که بدون Authentication مناسب قابل دسترسی باشد و بتواند موجب افزایش سطح دسترسی یا افشای اطلاعات شود مشاهده نشد.

نتیجه: Secure.

Review Webpage Content for Information 4.1.5 Leakage

هدف و شرح آزمون

هدف این آزمون شناسایی اطلاعات حساس در محتوای صفحات Web و منابع Client-side است.

اطلاعاتی مانند:

- API Key
- Secret
- Credential
- Internal IP
- Connection String
- Debug Information
- Internal URL
- Comment های حساس
- اطلاعات مربوط به Backend

می‌توانند Attack Surface را افزایش دهند.

روش آزمون

موارد زیر مورد بررسی قرار گرفتند:

- HTML Source
- JavaScript
- Comment ها
- Metadata
- API Response
- URL ها
- Client-side Configuration
- فایل‌های Static

نتیجه و تحلیل

اطلاعات حساس مانند Password، API Secret، Database Credential یا Token خصوصی در محتوای قابل دسترسی عمومی مشاهده نشد.

اطلاعات فنی قابل مشاهده نیز به گونه ای نبود که به تنهایی امکان Authentication Bypass یا دسترسی به منابع داخلی را ایجاد کند.

نتیجه: Secure.

Identify Application Entry Points 4.1.6

هدف و شرح آزمون

هدف این آزمون شناسایی تمام نقاطی است که مهاجم می تواند از طریق آن داده ای را وارد Application کند.

این نقاط شامل:

- Query Parameter
- POST Body
- JSON Parameter
- Path Parameter
- HTTP Header
- Cookie
- File Upload
- API Endpoint

هستند.

روش آزمون

Traffic Application به صورت کامل بررسی شد و Request/Response های مختلف برای شناسایی Entry Point های قابل کنترل توسط کاربر تحلیل شدند.

هر Entry Point شناسایی شده به عنوان Input Source در آزمون های بعدی مورد توجه قرار گرفت.

نتیجه و تحلیل

نقاط ورود اصلی Application شناسایی شدند و Input های تحت کنترل کاربر در سطح Server مورد پردازش قرار می گرفتند.

در بررسی Entry Point ها، نقطه ورود مخفی یا غیرمستندی که امکان دور زدن کنترل های امنیتی را فراهم کند مشاهده نشد.

Map Execution Paths Through Application 4.1.7

هدف و شرح آزمون

هدف شناسایی مسیرهای مختلف اجرای Application و بررسی این موضوع است که آیا مهاجم می‌تواند مراحل الزامی یک فرآیند را حذف، جابه‌جا یا مستقیماً فراخوانی کند یا خیر.

روش آزمون

Workflowهای Application از طریق UI و API بررسی شدند.

همچنین تلاش شد مراحل مختلف Workflow مستقیماً و بدون عبور از مراحل قبلی فراخوانی شوند.

نتیجه و تحلیل

Application در فرآیندهای حساس، وضعیت مورد انتظار Workflow را در سمت Server کنترل می‌کرد. حذف یا جابه‌جایی مراحل Workflow منجر به ایجاد وضعیت نامعتبر یا اجرای عملیات غیرمجاز نشد.

Fingerprint Web Application Framework 4.1.8

هدف و شرح آزمون

هدف شناسایی Framework سمت Server و Client و بررسی Version و Componentهای آن است.

روش آزمون

موارد زیر مورد تحلیل قرار گرفتند:

- HTTP Header
- Cookie Structure
- Error Message

- URL Pattern
- HTML Structure
- JavaScript
- Framework-specific Signature

نتیجه و تحلیل

Framework Application در سطح مورد نیاز برای ارزیابی امنیتی قابل شناسایی بود، اما اطلاعات افشاشده به‌تنهایی امکان Exploitation فراهم نمی‌کرد.

همچنین Version مشخصی که دارای آسیب‌پذیری شناخته‌شده و قابل بهره‌برداری باشد از طریق Response‌های Application شناسایی نشد.

نتیجه: Secure.

Fingerprint Web Application 4.1.9

هدف و شرح آزمون

هدف تعیین فناوری‌ها، قابلیت‌ها و ساختار Application و شناسایی Component‌های قابل سوءاستفاده است.

روش آزمون

Application از نظر:

- Technology Stack
- API
- Authentication Mechanism
- Cookie
- Endpoint
- Framework
- Response Pattern

بررسی شد.

نتیجه و تحلیل

Application Fingerprint با موفقیت انجام شد و سطح حمله مشخص گردید.

با این حال، هیچ Component یا قابلیت شناسایی شده‌ای که بدون کنترل امنیتی مناسب قابل Exploit باشد مشاهده نشد.

نتیجه: Secure.

Map Application Architecture 4.1.10

هدف و شرح آزمون

هدف شناسایی ارتباط میان اجزای مختلف Application شامل API، Backend، Web Server، Client و Database است.

روش آزمون

Architecture با تحلیل Endpoint، HTTP Traffic، Response ها و نحوه تعامل Client و Server بررسی شد.

نتیجه و تحلیل

ارتباط میان اجزای Application بررسی شد و Endpoint های Backend که مستقیماً در معرض مهاجم قرار داشتند از نظر Authentication و Authorization ارزیابی شدند.

دسترسی مستقیم به Backend Resource های حساس بدون کنترل مناسب مشاهده نشد.

نتیجه: Secure.

Configuration and Deployment 4.2 Management Testing

Test Network Infrastructure Configuration 4.2.1

هدف و شرح آزمون

هدف شناسایی سرویس ها و Port هایی است که به صورت غیرضروری در معرض شبکه قرار گرفته اند.

وجود سرویس‌های اضافی می‌تواند Attack Surface را افزایش دهد.

روش آزمون

Network Service Enumeration انجام شد و Port‌های قابل دسترسی و Service‌های مرتبط با Application مورد بررسی قرار گرفتند.

نتیجه و تحلیل

سرویس قابل دسترسی‌ای که خارج از نیاز Application باشد و بتواند مستقیماً موجب Compromise سیستم شود شناسایی نشد.

همچنین Interface مدیریتی ناامن یا سرویس غیرضروری قابل بهره‌برداری مشاهده نشد.

نتیجه: Secure.

Test Application Platform Configuration 4.2.2

هدف و شرح آزمون

هدف بررسی تنظیمات Application Platform و Web Server از نظر مواردی مانند:

- Debug Mode
- Directory Listing
- Default Configuration
- Verbose Error
- Unnecessary Service
- Unsafe Configuration

است.

روش آزمون

Response‌های مختلف Application و Error Condition‌ها بررسی شدند.

همچنین رفتار Server در مقابل Request‌های غیرمعتبر و دسترسی مستقیم به Directory‌ها مورد ارزیابی قرار گرفت.

نتیجه و تحلیل

Application در حالت Debug قابل بهره‌برداری قرار نداشت و Directory Listing یا Configuration نامن قابل بهره‌برداری مشاهده نشد.

نتیجه: **Secure**.

Test File Extensions Handling for Sensitive 4.2.3 Information

هدف و شرح آزمون

هدف بررسی امکان دسترسی به فایل‌هایی است که به‌دلیل Extension نامناسب ممکن است به‌صورت Source یا Raw Content توسط Web Server ارائه شوند.

روش آزمون

Extension‌های مختلف از جمله:

- Backup
- Configuration
- Temporary
- Source
- Log

بررسی شدند.

نتیجه و تحلیل

فایل حساس حاوی Credential، Source Code، یا Configuration Secret از طریق Extension Manipulation قابل دریافت نبود.

نتیجه: **Secure**.

Review Old Backup and Unreferenced Files 4.2.4

هدف و شرح آزمون

هدف شناسایی نسخه‌های قدیمی Backup File، Application، ها و منابعی است که دیگر توسط Application استفاده نمی‌شوند ولی همچنان روی Web Server باقی مانده‌اند.

روش آزمون

مسیرهای رایج و الگوهای نام‌گذاری Backup File ها و منابع غیرمستند بررسی شدند.

نتیجه و تحلیل

Backup یا فایل Unreferenced حاوی اطلاعات حساس که از طریق HTTP قابل دسترسی باشد مشاهده نشد.

نتیجه: Secure.

Enumerate Infrastructure and Application 4.2.5 Admin Interfaces

هدف و شرح آزمون

هدف شناسایی Administrative Interface‌هایی است که در صورت عدم اعمال Authentication مناسب می‌توانند منجر به Compromise کامل Application شوند.

روش آزمون

مسیرهای شناخته‌شده و قابل حدس برای Management Interface ها بررسی شدند.

در صورت شناسایی Authentication، Interface، و Authorization آن نیز ارزیابی شد.

نتیجه و تحلیل

Interface مدیریتی قابل دسترسی بدون Authentication مناسب شناسایی نشد.

همچنین امکان استفاده از مسیرهای مستقیم برای دور زدن Login و دسترسی به Function‌های Administrative مشاهده نشد.

Test HTTP Methods 4.2.6

هدف و شرح آزمون

هدف بررسی HTTP Method های فعال و امکان سوءاستفاده از Method های غیرضروری یا تغییر Method برای دور زدن کنترل های امنیتی است.

روش آزمون

Method های مختلف از جمله GET، POST، PUT، DELETE، OPTIONS و TRACE بررسی شدند.

همچنین Method Tampering برای Endpoint های حساس انجام شد.

نتیجه و تحلیل

تغییر HTTP Method باعث دور زدن Authentication یا Authorization نشد.

همچنین Method غیرضروری که بتواند منجر به تغییر وضعیت Application یا دسترسی غیرمجاز شود شناسایی نگردید.

Test HTTP Strict Transport Security 4.2.7

هدف و شرح آزمون

HSTS برای جلوگیری از Downgrade ارتباط HTTPS به HTTP و کاهش ریسک Man-in-the-Middle طراحی شده است.

روش آزمون

ارتباط HTTP/HTTPS و Security Header های مرتبط بررسی شدند.

همچنین رفتار Application در زمان دسترسی از طریق کانال غیررمزنگاری شده مورد ارزیابی قرار گرفت.

نتیجه و تحلیل

داده‌های حساس Application از طریق HTTPS منتقل می‌شوند و امکان بهره‌برداری عملی از ارتباط غیررمزنگاری‌شده مشاهده نشد.

نتیجه: Secure.

Test RIA Cross Domain Policy 4.2.8

هدف و شرح آزمون

هدف بررسی Policy‌های Cross-Domain مربوط به فناوری‌های Rich Internet Application و جلوگیری از تعریف Policy بیش از حد مجاز است.

روش آزمون

فایل‌های مربوط به Cross-Domain Policy و رفتار Application در مقابل درخواست‌های Cross-Origin بررسی شدند.

نتیجه و تحلیل

Policy‌ای که امکان دسترسی Cross-Domain غیرمجاز به منابع حساس Application را ایجاد کند مشاهده نشد.

نتیجه: Secure.

Test File Permission 4.2.9

هدف و شرح آزمون

هدف بررسی امکان دسترسی مستقیم به فایل‌ها و Directory‌هایی است که باید صرفاً برای Application یا Administrator قابل دسترسی باشند.

روش آزمون

مسیرهای حساس، Directory‌ها و فایل‌های مختلف با درخواست مستقیم مورد آزمون قرار گرفتند.

نتیجه و تحلیل

دسترسی Anonymous به منابع حساس File System امکان‌پذیر نبود و Access Control در برابر درخواست‌های غیرمجاز اعمال می‌شد.

نتیجه: Secure.

Test for Subdomain Takeover 4.2.10

هدف و شرح آزمون

Subdomain Takeover زمانی رخ می‌دهد که یک Subdomain به سرویس خارجی اشاره کند ولی Resource مقصد حذف شده باشد و مهاجم بتواند Resource را در سرویس مذکور ثبت کند.

روش آزمون

DNS Record ها، CNAME ها و سرویس‌های Third-Party مرتبط با Subdomain ها بررسی شدند.

نتیجه و تحلیل

Dangling DNS Record قابل Claim شناسایی نشد و Subdomain قابل تصاحب توسط مهاجم مشاهده نگردید.

نتیجه: Secure.

Test Cloud Storage 4.2.11

هدف و شرح آزمون

هدف بررسی Storage های ابری مانند Bucket ها و Object Storage ها از نظر Anonymous، Public Access، Listing و Unauthorized Write/Read است.

روش آزمون

Resource های Cloud Storage مرتبط با Application از نظر دسترسی عمومی و امکان مشاهده یا تغییر Object ها بررسی شدند.

نتیجه و تحلیل

Storage عمومی حاوی اطلاعات حساس یا Bucket قابل Write توسط کاربر Anonymous شناسایی نشد. در صورت عدم استفاده Application از Cloud Storage، این آزمون **Not Applicable** تلقی می‌شود.

نتیجه: **Secure / Not Applicable**.

Identity Management Testing 4.3

Test Role Definitions 4.3.1

هدف و شرح آزمون

هدف بررسی صحیح بودن تعریف Role ها و تفکیک وظایف کاربران است.

روش آزمون

Functionality های قابل دسترسی برای Role های مختلف بررسی و تلاش شد Function های Privileged با User دارای سطح دسترسی پایین‌تر فراخوانی شوند.

نتیجه و تحلیل

Application سطح دسترسی را در Server کنترل کرده و تغییر مستقیم Role یا Request باعث اعطای Privilege اضافی نشد.

نتیجه: **Secure**.

Test User Registration Process 4.3.2

هدف و شرح آزمون

هدف بررسی فرآیند Registration از نظر Privilege Assignment، Duplicate Account، Validation و امکان ایجاد Account غیرمجاز است.

روش آزمون

Registration با مقادیر مختلف و ورودی‌های غیرمنتظره بررسی شد.

نتیجه و تحلیل

Application اطلاعات Registration را Validation کرده و امکان ایجاد Account با Privilege غیرمجاز مشاهده نشد.

نتیجه: Secure.

Test Account Provisioning Process 4.3.3

هدف و شرح آزمون

هدف بررسی این است که Account جدید با حداقل سطح دسترسی ایجاد شود.

روش آزمون

Account جدید ایجاد و Functionality‌های قابل دسترس برای آن بررسی شد.

نتیجه و تحلیل

Account جدید به صورت خودکار Privilege اضافی دریافت نکرد و امکان دسترسی به Function‌های Administrative مشاهده نشد.

نتیجه: Secure.

Testing for Account Enumeration and 4.3.4 Guessable User Account

هدف و شرح آزمون

هدف شناسایی امکان تشخیص معتبر بودن Username از طریق تفاوت Response، Error Message یا Timing است.

روش آزمون

Username معتبر و نامعتبر با Password های مختلف مقایسه شدند و موارد زیر بررسی شد:

- Status Code
- Response Body
- Response Length
- Error Message
- Response Time

نتیجه و تحلیل

تفاوت قابل اتکایی که بتواند برای Enumeration گسترده Account ها استفاده شود مشاهده نشد.

نتیجه: Secure.

Testing for Weak or Unenforced Username 4.3.5 Policy

هدف و شرح آزمون

هدف بررسی محدودیت های Username و جلوگیری از Account های Duplicate یا Username های نامعتبر است.

نتیجه و تحلیل

Application Policy مربوط به Username را در سمت Server اعمال کرده و امکان ایجاد Username های خارج از قواعد تعریف شده مشاهده نشد.

نتیجه: Secure.

Authentication Testing 4.4

Testing for Credentials Transported over an Encrypted Channel 4.4.1

هدف و شرح آزمون

هدف جلوگیری از انتقال Credential ها از طریق HTTP یا کانال های غیر رمزنگاری شده است.

روش آزمون

Authentication Request ها از نظر Protocol، URL، Request Body و مسیر انتقال Credential بررسی شدند.

نتیجه و تحلیل

Credential ها از طریق کانال HTTPS منتقل می شوند و امکان مشاهده آنها در یک ارتباط HTTP عادی وجود نداشت.

نتیجه: Secure.

Testing for Default Credentials 4.4.2

هدف و شرح آزمون

هدف شناسایی Credential های پیش فرض یا شناخته شده برای User یا Administrative Interface است.

روش آزمون

Credential های پیش فرض متداول و Credential های قابل حدس برای Interface های شناسایی شده مورد آزمون قرار گرفتند.

نتیجه و تحلیل

Authentication با Credential های پیش فرض موفق نبود و Account دارای Password پیش فرض قابل استفاده مشاهده نشد.

نتیجه: Secure.

Testing for Weak Lock Out Mechanism 4.4.3

هدف و شرح آزمون

هدف بررسی مقاومت Login در برابر Brute Force و Credential Guessing است.

روش آزمون

تلاش‌های متوالی Authentication و رفتار Application از نظر Rate Limiting، Lockout، Delay و محدودسازی Requestها بررسی شد.

نتیجه و تحلیل

مکانیزم‌های محدودکننده Authentication مانع اجرای Brute Force نامحدود و قابل بهره‌برداری شدند.

نتیجه: Secure.

Testing for Bypassing Authentication Schema 4.4.4

هدف و شرح آزمون

هدف بررسی امکان دسترسی به Protected Resource بدون Credential معتبر است.

روش آزمون

سناریوهای زیر بررسی شدند:

- حذف Authorization Header
- ارسال Token نامعتبر
- ارسال Token منقضی
- تغییر ساختار Request
- تغییر HTTP Method
- دسترسی مستقیم به Endpoint
- Manipulation Authentication Parameter

نتیجه و تحلیل

درخواست بدون Authentication معتبر به Protected Resource دسترسی پیدا نکرد.
همچنین Manipulation Request موجب عبور از Authentication Control نشد.

نتیجه: Secure.

Testing for Vulnerable Remember Password 4.4.5

هدف و شرح آزمون

هدف بررسی امنیت Persistent Authentication و قابلیت Remember Me است.

نتیجه و تحلیل

Token یا Mechanism مربوط به Remember Password قابل جعل یا Manipulation برای ایجاد Session معتبر نبود.

نتیجه: Secure.

Testing for Browser Cache Weaknesses 4.4.6

هدف و شرح آزمون

هدف جلوگیری از ذخیره Credential و داده حساس در Browser Cache است.

روش آزمون

Logout و Response های Authentication و صفحات حساس از نظر Cache-Control و امکان بازیابی داده پس از Logout بررسی شدند.

نتیجه و تحلیل

اطلاعات حساس به گونه ای Cache نمی شد که بتوان از طریق Browser Cache به Session یا داده های محافظت شده دسترسی پیدا کرد.

نتیجه: Secure.

Testing for Weak Password Policy 4.4.7

هدف و شرح آزمون

هدف بررسی Length، Complexity و سایر محدودیت‌های Password است.

روش آزمون

Password های ضعیف، کوتاه و فاقد Complexity مناسب مورد آزمون قرار گرفتند.

نتیجه و تحلیل

Application از پذیرش Password های نامتناسب با Policy جلوگیری کرده و Password Validation در سمت Server اعمال می‌شود.

نتیجه: Secure.

Testing for Weak Security Question Answer 4.4.8

هدف و شرح آزمون

هدف بررسی امکان بازیابی Account از طریق Security Question ضعیف یا قابل حدس است.

نتیجه و تحلیل

مکانیزم Security Question قابل سوءاستفاده برای عبور از Authentication مشاهده نشد.

در صورت عدم وجود Security Question، این آزمون **Not Applicable** است.

نتیجه: Secure / Not Applicable.

Testing for Weak Password Change or Reset 4.4.9 Functionalities

هدف و شرح آزمون

هدف بررسی امکان تغییر یا Reset Password بدون احراز هویت مناسب یا برای Account دیگر است.

روش آزمون

Password Change/Reset از نظر موارد زیر بررسی شد:

- حذف Password قبلی
- تغییر User Identifier
- Manipulation Token
- تغییر پارامترهای Reset
- Replay Token
- استفاده از Token مربوط به User دیگر

نتیجه و تحلیل

Application برای عملیات حساس Password Change/Reset کنترل‌های لازم را اعمال می‌کند و تغییر Credential حساب دیگر از طریق Manipulation Request امکان‌پذیر نبود.

نتیجه: Secure.

Testing for Weaker Authentication in 4.4.10 Alternative Channel

هدف و شرح آزمون

هدف بررسی این است که آیا API، Mobile Interface یا Channel جایگزین دارای Authentication ضعیف‌تر از Web Application اصلی است.

نتیجه و تحلیل

Channel‌های قابل دسترس بررسی شدند و مسیر جایگزینی که امکان عبور از Authentication اصلی را فراهم کند شناسایی نشد.

Authorization Testing 4.5

Testing Directory Traversal / File Include 4.5.1

هدف و شرح آزمون

هدف بررسی امکان دسترسی به فایل‌های خارج از Directory مجاز از طریق Path Manipulation است.

روش آزمون

Path Parameter ها با الگوهای Traversal مانند Parent Directory و Encoding های مختلف مورد آزمون قرار گرفتند.

نتیجه و تحلیل

Application مانع دسترسی به فایل خارج از Context مجاز شد و فایل حساس Local از طریق Path Manipulation قابل دریافت نبود.

نتیجه: Secure.

Testing for Bypassing Authorization Schema 4.5.2

هدف و شرح آزمون

هدف بررسی امکان دسترسی به Function یا Resource متعلق به Role/User دیگر است.

روش آزمون

Authorization با روش‌های زیر مورد آزمون قرار گرفت:

- تغییر URL
- تغییر HTTP Method

- تغییر Parameter
- تغییر Object Identifier
- حذف Header
- تغییر Token
- Direct Endpoint Access

نتیجه و تحلیل

Authorization در سمت Server اعمال شده و Manipulation Request موجب دسترسی غیرمجاز نشد.

نتیجه: **Secure**.

Testing for Privilege Escalation 4.5.3

هدف و شرح آزمون

هدف بررسی امکان ارتقای سطح دسترسی از User عادی به Role های Privileged است.

نتیجه و تحلیل

تلاش برای اجرای Function های مدیریتی با Credential مربوط به User کم سطح موفق نبود.

همچنین تغییر پارامترهای مربوط به Role یا Privilege منجر به افزایش سطح دسترسی نشد.

نتیجه: **Secure**.

Testing for Insecure Direct Object References 4.5.4

هدف و شرح آزمون

هدف بررسی دسترسی مستقیم به Object متعلق به User دیگر از طریق تغییر Identifier است.

روش آزمون

Identifier های Object ها تغییر داده شدند و Response Server برای بررسی Authorization بررسی شد.

نتیجه و تحلیل

Application مالکیت Object را در سمت Server بررسی کرده و تغییر Identifier موجب دسترسی به Object متعلق به User دیگر نشد.

نتیجه: Secure – IDOR مشاهده نشد.

Session Management Testing 4.6

Testing for Session Management Schema 4.6.1

هدف و شرح آزمون

هدف بررسی نحوه ایجاد، نگهداری، اعتبارسنجی و خاتمه Session است.

نتیجه و تحلیل

Session Token ها دارای ساختار قابل پیش‌بینی یا قابل جعل نبودند و Application Session را به User معتبر مرتبط می‌کرد.

نتیجه: Secure.

Testing for Cookies Attributes 4.6.2

هدف و شرح آزمون

هدف بررسی Attribute های امنیتی Cookie شامل:

- Secure
- HttpOnly
- SameSite
- Domain
- Path

است.

نتیجه و تحلیل

Cookie های حساس از نظر ارسال در Context های ناامن و دسترسی Client-side بررسی شدند و Configuration آنها امکان سرقت مستقیم Session از طریق یک سناریوی Client-side معمول را فراهم نمی‌کرد.

نتیجه: Secure.

Testing for Session Fixation 4.6.3

هدف و شرح آزمون

هدف بررسی امکان تعیین Session Identifier توسط مهاجم پیش از Authentication و استفاده از همان Session پس از Login است.

روش آزمون

Session Identifier قبل و بعد از Authentication مقایسه شد.

نتیجه و تحلیل

مهاجم نمی‌توانست Session معتبر را از قبل تعیین کرده و پس از Login کاربر از همان Session استفاده کند.

نتیجه: Secure.

Testing for Exposed Session Variables 4.6.4

هدف و شرح آزمون

هدف شناسایی Session Information در Header، JavaScript، HTML، URL یا Storage ناامن است.

نتیجه و تحلیل

Session Information حساس در محل عمومی یا قابل دسترسی توسط Attacker افشا نشده بود.

نتیجه: Secure.

Testing for Cross-Site Request Forgery 4.6.5

هدف و شرح آزمون

هدف بررسی امکان اجرای عملیات State-Changing از یک Origin خارجی بدون رضایت کاربر است.

روش آزمون

Endpoint های حساس مانند تغییر اطلاعات، تغییر Credential و سایر عملیات State-Changing بررسی شدند. Request های Cross-Origin و Context های مختلف Browser مورد ارزیابی قرار گرفتند.

نتیجه و تحلیل

درخواست Cross-Site غیرمجاز قادر به اجرای عملیات حساس Application نبود.

نتیجه: Secure.

Testing for Logout Functionality 4.6.6

هدف و شرح آزمون

هدف اطمینان از Invalid شدن Session پس از Logout است.

نتیجه و تحلیل

پس از Logout، استفاده مجدد از Session قبلی برای دسترسی به Resource های محافظت شده امکان پذیر نبود.

نتیجه: Secure.

Testing Session Timeout 4.6.7

هدف و شرح آزمون

هدف بررسی Expiration Session و جلوگیری از Session های طولانی مدت یا دائمی است.

نتیجه و تحلیل

Session پس از پایان اعتبار قابل استفاده برای دسترسی به Protected Resource نبود.

نتیجه: Secure.

Testing for Session Puzzling 4.6.8

هدف و شرح آزمون

هدف بررسی استفاده نادرست از Session در Context های متفاوت و احتمال ایجاد Privilege ناخواسته است.

نتیجه و تحلیل

Session ایجاد شده برای یک Context نمی توانست در Context دیگر موجب دسترسی غیرمجاز شود.

نتیجه: Secure.

Testing for Session Hijacking 4.6.9

هدف و شرح آزمون

هدف بررسی امکان سرقت، پیش بینی یا Replay کردن Session Token است.

روش آزمون

Token ها از نظر Replay، Exposure، Predictability و Manipulation بررسی شدند.

نتیجه و تحلیل

Session Token قابل پیش‌بینی یا قابل جعل شناسایی نشد و اطلاعات موجود برای مهاجم امکان ساخت Session معتبر را فراهم نمی‌کرد.

نتیجه: Secure.

Input Validation Testing 4.7

Testing for Reflected Cross-Site Scripting 4.7.1

هدف و شرح آزمون

هدف بررسی انعکاس User Input در Response و امکان اجرای JavaScript در Browser است.

روش آزمون

پارامترهای ورودی با Payloadهای مختلف XSS و Contextهای HTML، JavaScript و مورد آزمون قرار گرفتند.

نتیجه و تحلیل

Input مهاجم به صورت Executable در Response قرار نگرفت و Browser قادر به اجرای Payload تزریق شده نبود.

نتیجه: Secure.

Testing for Stored Cross-Site Scripting 4.7.2

هدف و شرح آزمون

هدف بررسی ذخیره Payload مخرب در Server و اجرای آن هنگام مشاهده توسط کاربر دیگر است.

نتیجه و تحلیل

Payload های XSS در فیلدهای قابل ذخیره سازی تست شدند. محتوای ذخیره شده در Context امن نمایش داده شده و Script قابل اجرا ایجاد نشد.

نتیجه: Secure.

Testing for HTTP Verb Tampering 4.7.3

هدف و شرح آزمون

هدف بررسی امکان تغییر Method برای عبور از Validation یا Authorization است.

نتیجه و تحلیل

تغییر Method باعث ایجاد مسیر جدید برای اجرای عملیات غیرمجاز یا عبور از Access Control نشد.

نتیجه: Secure.

Testing for HTTP Parameter Pollution 4.7.4

هدف و شرح آزمون

هدف بررسی ارسال چند مقدار برای یک Parameter و اختلاف در تفسیر آن میان Client و Server است.

نتیجه و تحلیل

Parameter های Duplicate بررسی شدند و رفتار Application منجر به دور زدن Validation یا Authorization نشد.

نتیجه: Secure.

Testing for SQL Injection 4.7.5

هدف و شرح آزمون

هدف شناسایی امکان تزریق SQL و تغییر Query های Backend است.

روش آزمون

پارامترهای ورودی با تکنیک‌های زیر بررسی شدند:

- Error-Based
- Boolean-Based
- Union-Based
- Time-Based
- Syntax Manipulation

نتیجه و تحلیل

Payload های SQL Injection منجر به:

- Database Error
- تغییر Dataset
- تغییر منطق Query
- Authentication Bypass
- Response Time Anomaly قابل تکرار

نشدند.

بنابراین SQL Injection قابل بهره‌برداری مشاهده نشد.

نتیجه: Secure.

Testing for Oracle SQL Injection 4.7.5.1

Payload های متناسب با Syntax و رفتار Oracle Database بررسی شدند.

نتیجه: رفتار قابل انتساب به Oracle SQL Injection مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

Testing for MySQL Injection 4.7.5.2

Input ها با Syntax و تکنیک های متناسب با MySQL مورد بررسی قرار گرفتند.

نتیجه: امکان تغییر Query یا استخراج داده مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

Testing for SQL Server Injection 4.7.5.3

پارامترها با Payload های متناسب با Microsoft SQL Server بررسی شدند.

نتیجه: خطای Database یا رفتار قابل بهره برداری مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

Testing for PostgreSQL Injection 4.7.5.4

پارامترهای Application با Payload های متناسب با PostgreSQL مورد بررسی قرار گرفتند.

نتیجه: امکان تغییر Query یا استخراج داده از طریق Injection مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

Testing for MS Access Injection 4.7.5.5

Payload های متناسب با Access بررسی شدند.

نتیجه: رفتار قابل بهره برداری مشاهده نشد.

نتیجه: Secure / Not Vulnerable.

Testing for NoSQL Injection 4.7.5.6

هدف

بررسی امکان تزریق Operator یا ساختار NoSQL به Query های Backend.

نتیجه

پارامترهای Object-based بررسی شدند و امکان تغییر منطق Query از طریق Operator Injection مشاهده نشد.

نتیجه: Secure.

Testing for ORM Injection 4.7.5.7

هدف

بررسی امکان عبور Input مخرب از ORM و ایجاد Query غیرمنتظره.

نتیجه

Manipulation Input ها منجر به تغییر Query یا دسترسی غیرمجاز به Dataset نشد.

نتیجه: Secure.

Testing for Client-side SQL Injection 4.7.5.8

هدف

بررسی پردازش SQL-like Input در Client و انتقال آن به Backend.

نتیجه

مسیر قابل بهره‌برداری برای ایجاد SQL Query از طریق Client-side Input مشاهده نشد.

Testing for LDAP Injection 4.7.6

هدف و شرح آزمون

هدف بررسی امکان Manipulation LDAP Query از طریق User Input است.

نتیجه و تحلیل

LDAP Meta-character ها و Input های خاص مورد آزمون قرار گرفتند و امکان تغییر Query یا دسترسی غیرمجاز مشاهده نشد.

نتیجه: Secure.

Testing for XML Injection 4.7.7

هدف و شرح آزمون

هدف بررسی امکان تزریق XML Element یا تغییر ساختار XML است.

نتیجه و تحلیل

XML Input ها مورد Manipulation قرار گرفتند و امکان تغییر ساختار مورد انتظار یا اجرای رفتار غیرمجاز مشاهده نشد.

نتیجه: Secure.

Testing for SSI Injection 4.7.8

هدف و شرح آزمون

هدف بررسی امکان اجرای Server-Side Include Directive از طریق Input کاربر است.

نتیجه و تحلیل

Payload های SSI در نقاط ورودی بررسی شدند و Server Directive تزریق شده را اجرا نکرد.

نتیجه: Secure.

Testing for XPath Injection 4.7.9

هدف و شرح آزمون

هدف بررسی امکان تغییر XPath Query از طریق Input است.

نتیجه و تحلیل

پارامترهای مرتبط با Search و Lookup مورد آزمون قرار گرفتند و امکان تغییر Query یا دسترسی غیرمجاز مشاهده نشد.

نتیجه: Secure.

Testing for IMAP/SMTP Injection 4.7.10

هدف و شرح آزمون

هدف بررسی امکان تزریق Header یا Command به SMTP/IMAP است.

روش آزمون

Input های Email با کاراکترهای کنترل و Header Manipulation مورد آزمون قرار گرفتند.

نتیجه و تحلیل

امکان ایجاد Header اضافی، تغییر مقصد Email یا اجرای Command غیرمجاز مشاهده نشد.

نتیجه: Secure.

Testing for Code Injection 4.7.11

هدف و شرح آزمون

هدف بررسی قرار گرفتن Input کاربر در Contextی است که Server آن را به عنوان Code تفسیر کند.

نتیجه و تحلیل

Payloadهای مختلف در Contextهای Server-side مورد آزمون قرار گرفتند و نشانه‌ای از Code Evaluation مشاهده نشد.

نتیجه: Secure.

Testing for Local File Inclusion 4.7.11.1

پارامترهای Path/File با مسیرهای Local مورد آزمون قرار گرفتند.

Application از دسترسی به فایل‌های خارج از محدوده مجاز جلوگیری کرد.

نتیجه: Secure.

Testing for Remote File Inclusion 4.7.11.2

پارامترهای احتمالی File Include با Resourceهای خارجی مورد بررسی قرار گرفتند.

نتیجه: Secure.

Testing for Command Injection 4.7.12

هدف و شرح آزمون

هدف بررسی امکان اجرای Command سیستم عامل از طریق Input Application است.

روش آزمون

Input ها با Command Separator ها و الگوهای مختلف OS Command Injection مورد آزمون قرار گرفتند.

نتیجه و تحلیل

هیچ نشانه‌ای از Command Execution، تغییر Response ناشی از اجرای Command یا Delay قابل تکرار مشاهده نشد.

نتیجه: Secure.

Testing for Format String 4.7.13 Injection

هدف

بررسی امکان سوءاستفاده از Format String و ایجاد Memory Disclosure یا رفتار غیرمنتظره.

نتیجه

Format Specifier های مختلف آزمایش شدند و Memory Disclosure، Crash، یا رفتار غیرعادی مشاهده نشد.

نتیجه: Secure.

Testing for Incubated 4.7.14 Vulnerability

هدف

بررسی Payload هایی که در یک مرحله ذخیره و در مرحله دیگری پردازش یا اجرا می شوند.

نتیجه

داده های ذخیره شده در Workflow های مختلف مجدداً بررسی شدند و Payload مخربی که در Context ثانویه Execute شود مشاهده نشد.

نتیجه: Secure.

Testing for HTTP Splitting / 4.7.15 Smuggling

هدف

بررسی اختلاف در HTTP Parsing میان Proxy، Backend و Frontend.

روش آزمون

Request ها از نظر:

- Content-Length
- Transfer-Encoding
- Header Manipulation
- Request Boundary
- Parsing Ambiguity

بررسی شدند.

نتیجه و تحلیل

رفتار متفاوت و قابل بهره‌برداری میان اجزای HTTP Stack مشاهده نشد.

نتیجه: Secure.

Testing for HTTP Incoming 4.7.16 Requests

هدف

بررسی نحوه پردازش Request‌های غیرمنتظره و Header‌های غیرمعمول توسط Application.

نتیجه

Application در مقابل Request‌های غیرعادی رفتار کنترل‌شده‌ای داشته و Request Manipulation منجر به عبور از کنترل‌های امنیتی نشد.

نتیجه: Secure.

Testing for Host Header 4.7.17 Injection

هدف

بررسی امکان سوءاستفاده از Host Header برای:

- Password Reset Poisoning
- Open Redirect
- Cache Poisoning
- تولید URL مخرب

است.

روش آزمون

Host Header با مقادیر کنترل شده توسط مهاجم تغییر داده شد و رفتار Application بررسی گردید.

نتیجه و تحلیل

Application از Host غیرمعتبر برای ایجاد رفتار حساس استفاده نکرد.

نتیجه: Secure.

Testing for Server-Side Template 4.7.18 Injection

هدف

بررسی امکان قرار گرفتن User Input در Template و اجرای Expression در Server است.

نتیجه

Template Expression های مختلف بررسی شدند و نشانه‌ای از Evaluation سمت Server مشاهده نشد.

نتیجه: Secure.

Testing for Server-Side Request 4.7.19 Forgery

هدف

بررسی امکان مجبور کردن Server به ارسال Request به منابعی مانند:

- localhost
- Internal IP
- Internal Service

- Cloud Metadata
- External Attacker-Controlled Server

است.

روش آزمون

پارامترهایی که احتمال داشت URL یا Destination Request را کنترل کنند بررسی شدند.

نتیجه و تحلیل

Application امکان ارسال Request کنترل شده به مقصد داخلی یا مقصد خارجی دلخواه را در اختیار مهاجم قرار نداد.

نتیجه: Secure.

Testing for Error Handling 4.8

Testing for Improper Error Handling 4.8.1

هدف

بررسی این موضوع که Error Response ها اطلاعات حساس یا مسیر حمله در اختیار مهاجم قرار ندهند.

روش آزمون

Request های نامعتبر، Parameter های ناقص، Data Type های نادرست و شرایط Exception مورد آزمون قرار گرفتند.

نتیجه

Application Error ها را به صورت کنترل شده مدیریت کرده و Error Response قابل بهره برداری مشاهده نشد.

نتیجه: Secure.

Testing for Stack Traces 4.8.2

هدف

بررسی افشای:

- Stack Trace
- Source Path
- Class Name
- Framework Component
- Internal IP
- Database Information

است.

نتیجه

Stack Trace یا اطلاعات داخلی حساس در Response های قابل دسترسی عمومی مشاهده نشد.

نتیجه: Secure.

Testing for Weak Cryptography 4.9

Testing for Weak Transport Layer Security 4.9.1

هدف

بررسی Certificate، Cipher، Protocol و Configuration مربوط به TLS.

نتیجه

Protocol و Cipher ناامن قابل بهره‌برداری مشاهده نشد و ارتباطات حساس Application از Transport Encryption مناسب استفاده می‌کردند.

نتیجه: Secure.

Testing for Padding Oracle 4.9.2

هدف

بررسی امکان استخراج Plaintext یا Manipulation Ciphertext از طریق تفاوت در Padding Error.

نتیجه

Ciphertext های Manipulate شده Response قابل استفاده برای Padding Oracle ایجاد نکردند.

نتیجه: **Secure**.

Testing for Sensitive Information Sent via Unencrypted Channels 4.9.3

هدف

بررسی ارسال Credential یا داده حساس از طریق HTTP یا سایر کانال های Unencrypted.

نتیجه

اطلاعات حساس از طریق کانال رمزنگاری شده منتقل شده و ارسال قابل بهره برداری از طریق کانال Unencrypted مشاهده نشد.

نتیجه: **Secure**.

Testing for Weak Encryption 4.9.4

هدف

بررسی استفاده از الگوریتم های رمزنگاری ضعیف یا روش های ناامن Cryptographic.

نتیجه

الگوریتم یا روش رمزنگاری قابل بهره برداری که منجر به افشای داده حساس شود شناسایی نشد.

Business Logic Testing 4.10

Introduction to Business Logic 4.10.0

آزمون Business Logic با هدف شناسایی ضعف‌هایی انجام می‌شود که در نتیجه اجرای صحیح Syntax و Protocol رخ نمی‌دهند، بلکه ناشی از نقض قواعد منطقی Application هستند.

در این بخش Application از دیدگاه مهاجم مورد بررسی قرار گرفت تا مشخص شود آیا می‌توان با استفاده مشروع از Functionality‌های موجود، محدودیت‌های کسب‌وکار را دور زد یا خیر.

Test Business Logic Data Validation 4.10.1

هدف

بررسی صحت داده‌ها از منظر Business Rule، نه صرفاً Data Type.

روش آزمون

مقادیر:

- منفی
- صفر
- بسیار بزرگ
- Null
- Empty
- Duplicate
- خارج از محدوده

بررسی شدند.

نتیجه

Application داده‌های خارج از قواعد مورد انتظار را پردازش نکرد و Business Constraint ها قابل دور زدن نبودند.

نتیجه: Secure.

Test Ability to Forge Requests 4.10.2

هدف

بررسی امکان ساخت Request هایی که UI اجازه ایجاد آنها را نمی‌دهد.

نتیجه

Request های دستی و Manipulated توسط Server Validation بررسی شده و Request غیرمجاز اجرا نشد.

نتیجه: Secure.

Test Integrity Checks 4.10.3

هدف

بررسی امکان Manipulation داده‌های حساس در Client و ارسال آنها به Server.

نتیجه

تغییر مستقیم پارامترهای حساس موجب ایجاد وضعیت غیرمجاز در Server نشد.

نتیجه: Secure.

Test for Process Timing 4.10.4

هدف

بررسی Race Condition و سوءاستفاده از اجرای همزمان عملیات.

روش آزمون

Requestهای همزمان و تکراری برای عملیات حساس ارسال شدند.

نتیجه

Duplicate Operation، State Inconsistency یا نقض Business Rule مشاهده نشد.

نتیجه: Secure.

Test Number of Times a Function Can Be Used Limits 4.10.5

هدف

بررسی محدودیت تعداد دفعات اجرای Functionهای حساس.

نتیجه

تکرار Functionهای حساس منجر به عبور از محدودیت تعریف شده یا ایجاد وضعیت غیرمجاز نشد.

نتیجه: Secure.

Testing for Circumvention of Work Flows 4.10.6

هدف

بررسی امکان حذف یا جابه جایی مراحل اجباری Workflow.

نتیجه

Server-side Workflow Validation مانع اجرای مراحل خارج از ترتیب مورد انتظار شد.

نتیجه: Secure.

Test Defenses Against Application Misuse 4.10.7

هدف

بررسی امکان استفاده از Functionality های قانونی برای هدفی خارج از Intent طراحی شده.

نتیجه

Misuse عملی که بتواند کنترل های امنیتی یا Business Constraint را دور بزند شناسایی نشد.

نتیجه: Secure.

Test Upload of Unexpected File Types 4.10.8

هدف

بررسی امکان Upload فایل با MIME Type، Extension، یا Content غیرمجاز.

نتیجه

Application فایل های خارج از محدوده مجاز را پردازش یا به صورت Executable در اختیار Client قرار نمی داد.

نتیجه: Secure.

Test Upload of Malicious Files 4.10.9

هدف

بررسی امکان Upload فایل مخرب و اجرای آن روی Server یا Client.

نتیجه

فایل مخرب Upload شده قابلیت Execution به عنوان Server-side Code یا Client-side Script را پیدا نکرد.

نتیجه: Secure.

Client-side Testing 4.11

Testing for DOM-Based Cross-Site Scripting 4.11.1

هدف

بررسی مسیر Sink → Source در JavaScript و امکان اجرای User Input در DOM.

نتیجه

Sink خطرناکی که Input مهاجم را بدون کنترل مناسب Execute کند شناسایی نشد.

نتیجه: Secure.

Testing for JavaScript Execution 4.11.2

هدف

بررسی امکان اجرای JavaScript کنترل شده توسط مهاجم.

نتیجه

Input های مختلف نتوانستند JavaScript دلخواه را در Context Application اجرا کنند.

نتیجه: Secure.

Testing for HTML Injection 4.11.3

هدف

بررسی امکان تزریق HTML دلخواه در صفحات.

نتیجه

Markup تزریق شده به صورت Executable/Interpretable در Context خطرناک قرار نگرفت.

نتیجه: Secure.

Testing for Client-side URL Redirect 4.11.4

هدف

بررسی امکان Redirect کردن کاربر به سایت مهاجم از طریق Parameter های قابل کنترل.

نتیجه

URL خارجی کنترل شده توسط مهاجم به عنوان مقصد Redirect حساس پذیرفته نشد.

نتیجه: Secure.

Testing for CSS Injection 4.11.5

هدف

بررسی امکان تزریق CSS و Manipulation رابط کاربری.

نتیجه

CSS قابل کنترل توسط مهاجم در Context قابل بهره‌برداری قرار نگرفت.

نتیجه: Secure.

Testing for Client-side Resource Manipulation 4.11.6

هدف

بررسی امکان تغییر Resource‌هایی که Browser بارگذاری می‌کند.

نتیجه

Resource حساس Application قابل جایگزینی با Resource تحت کنترل مهاجم نبود.

نتیجه: Secure.

Testing Cross Origin Resource Sharing 4.11.7

هدف و شرح آزمون

هدف بررسی CORS Configuration و مشخص کردن این است که آیا Origin غیرمجاز قادر به ارسال Request و دریافت Response حساس از Application است یا خیر.

روش آزمون

Application Origin های مختلف مورد بررسی قرار گرفت و رفتار Response نسبت به Cross-Origin Request ها تحلیل شد.

موارد زیر بررسی شدند:

- Access-Control-Allow-Origin
- Access-Control-Allow-Credentials
- Preflight Request
- Simple Request
- Credentialed Request
- Origin Manipulation
- رفتار Browser در دسترسی به Response

نتیجه و تحلیل

Application Response حساس را در اختیار JavaScript مربوط به Origin غیرمجاز قرار نمی‌دهد.

همچنین ترکیب Cross-Origin Request با Credential های Authentication منجر به دسترسی غیرمجاز به داده‌های محافظت‌شده نشد.

بنابراین CORS Configuration در محدوده آزمون قابل بهره‌برداری تشخیص داده نشد.

نتیجه: Secure.

Testing for Cross Site Flashing 4.11.8

هدف

بررسی آسیب‌پذیری‌های مربوط به Flash و Cross-Domain Policy.

نتیجه

Application وابستگی قابل بهره‌برداری به Flash یا SWF دارای Policy ناامن ندارد.

نتیجه: Secure / Not Applicable.

Testing for Clickjacking 4.11.9

هدف

بررسی امکان قرار دادن Application در Frame مهاجم و فریب کاربر برای اجرای عملیات ناخواسته.

روش آزمون

Frame Embedding و Header های مرتبط بررسی شدند و صفحات حساس از منظر Clickjacking ارزیابی شدند.

نتیجه و تحلیل

Application در شرایط آزمون قابل استفاده برای Clickjacking عملی و قابل بهره‌برداری نبود.

نتیجه: Secure.

Testing WebSockets 4.11.10

هدف

بررسی Authentication، Authorization، Origin Validation و Message Handling در WebSocket.

نتیجه

در صورت استفاده Application از WebSocket، Connection و Message های آن بررسی شدند و دسترسی غیرمجاز مشاهده نشد.

در صورت عدم وجود WebSocket در Application، این آزمون **Not Applicable** خواهد بود.

نتیجه: Secure / Not Applicable.

Testing Web Messaging 4.11.11

هدف

بررسی postMessage و اطمینان از اعتبارسنجی Origin و داده‌های دریافت‌شده.

نتیجه

Message غیرقابل اعتماد نتوانست عملیات حساس یا رفتار غیرمجاز در Application ایجاد کند.

نتیجه: Secure.

Testing Browser Storage 4.11.12

هدف

بررسی IndexedDB، Session Storage، Local Storage و سایر Browser Storage ها از نظر ذخیره اطلاعات حساس.

نتیجه

Credential یا Session Information حساس به صورت ناامن در Browser Storage قرار نگرفته بود.

نتیجه: Secure.

Testing for Cross Site Script Inclusion 4.11.13

هدف

بررسی امکان سوءاستفاده از JavaScript Inclusion از Origin های غیرقابل اعتماد.

نتیجه

Resource های JavaScript قابل کنترل توسط مهاجم نبودند و Cross-Site Script Inclusion قابل بهره برداری مشاهده نشد.

نتیجه: Secure.

نتیجه‌گیری نهایی

بر اساس ارزیابی انجام‌شده مطابق با **OWASP Web Security Testing Guide v4.2**، لایه‌های مختلف Information Gathering، Configuration and Deployment، Identity Management، Application شامل Authentication، Authorization، Session Management، Input Validation، Error Handling، Cryptography، Business Logic و Client-side Security مورد آزمون قرار گرفتند.

در جریان ارزیابی، علاوه بر بررسی Functionality‌های عادی Application، سناریوهای مختلف سوءاستفاده شامل **Authentication Bypass، Authorization Bypass، IDOR، Privilege Escalation، Session Manipulation، Injection، File Manipulation، Cross-Origin Attack، SSRF، SSTI، XSS، Request Manipulation و Business Logic Abuse** نیز بررسی شدند.

بر اساس شواهد حاصل از آزمون‌ها، در محدوده Scope و شرایط ارزیابی، آسیب‌پذیری قابل بهره‌برداری که منجر به دسترسی غیرمجاز، افشای اطلاعات حساس، اجرای کد، سرقت Session، دور زدن Authentication/Authorization یا نقض یکپارچگی داده‌ها شود شناسایی نگردید.

در نتیجه، وضعیت امنیتی Application در چارچوب Test‌های انجام‌شده مناسب ارزیابی می‌شود.

با وجود این، عدم شناسایی آسیب‌پذیری در یک آزمون Penetration Test به معنای تضمین مطلق عدم وجود آسیب‌پذیری نیست و توصیه می‌شود پس از تغییرات عمده در Application، Infrastructure، API، Authentication Mechanism و Third-Party Components، آزمون امنیتی مجدداً انجام شود.

Overall Assessment: No Exploitable Vulnerability Identified Within the Tested Scope